CCF Control				Applicability																					Mapping																					
CCF ID	Control Domain	Control Name	Control Description	NIST Cybersecurity	BSI C5	CIS V8	MLPS	ISO 22301	Cyber Essentials UK	ENS	ISO 27001	ISO 27002 (ISO 27001 Annex A)	ISO 27017	ISO 27018	TX_RAMP L1	FEDRAMP Tailored	FEDRAMP Moderate	HIPAA Security	IRAP	ISMAP	MAS	PCI-DSS 4.0	KPSI	SOC 2	NIST Cybersecurity Refe	BSI C5 Ref #	CIS V8 Ref #	MLPS Ref #	ISO 22301 Ref #	Cyber Essentials UK Ref #	ENS Ref #	ISO 27001 Ref #	ISO 27002 Ref #	ISO 27017 Ref #	ISO 27018 Ref #	TX_RAMP L1 Ref #	FEDRAMP TAILORED Ref #	FEDRAMP MODERATE Ref #	HIPAA Security Ref #	IRAP Ref #	ISMAP Ref #	MAS Ref #	PCI-DSS V4 Ref #	KPSI Ref #	SOC 2 Refe
AM-01	Asset Management	Inventory Management	Organization maintains an inventory of information systems, which is reconciled on a periodic basis.	X	X	X	X			X					X	X	X	X	X	X	X	X	X	X	ID.AM-2 ID.AM-1	AM-01 AM-06	1.1 6.6	8.1.4.2 8.1.5.2			8 9 10 26					CM-08	CM-08	CM-08 CM-08 (01)	164.310(d)(1)	ISM-1551 ISM-1649 ISM-1359 ISM-1753 ISM-1493 ISM-0336	8.1.1.1 8.1.1.2 8.1.1.3 8.1.1.4 8.1.1.5 8.1.1.6.PB 8.3.1.3 8.3.1.8 8.3.1.11 11.2.1.9 18.1.3.12 18.1.2.4	3.3	12.5.1, 12.5.2, 12.5.2.1, 9.5.1.1	3.1.1	CC6.1
AM-02	Asset Management	Inventory Management: Applications	Organization maintains an inventory of application assets, which is reconciled on a periodic basis.	X	X	X	X			X					X	X	X	X	X	X	X	X	X	X	ID.AM-2 ID.AM-1	AM-01 AM-06	1.1 6.6	8.1.4.2 8.1.5.2			8 9 10 26					CM-08	CM-08	CM-08 CM-08 (01)	164.310(d)(1)	ISM-1551 ISM-1649 ISM-1359 ISM-1753 ISM-1493 ISM-0336	8.1.1.1 8.1.1.2 8.1.1.3 8.1.1.4 8.1.1.5 8.1.1.6.PB 8.3.1.3 8.3.1.8 8.3.1.11 11.2.1.9 18.1.3.12 18.1.2.4	3.3	12.5.1, 12.5.2, 12.5.2.1, 9.5.1.1	3.1.1	CC6.1
AM-03	Asset Management	Inventory Reconciliation: ARD Table	Organization reconciles network discovery scans against the established device inventory on a quarterly basis; non-inventoried devices are assigned an owner.			X	X															X					1.2 1.3 1.5	8.1.10.2																	11.2, 11.2.1, 11.2.2, 11.3.1, 11.3.1.3, 11.4.5, 11.4.6		
AM-04	Asset Management	Inventory Reconciliation: Logging	Organization reconciles the enterprise log repository against the established device inventory on a quarterly basis; non-inventoried devices are assigned an owner.			X											X					X					1.4											CM-08 (03)						12.5.1, 12.5.2, 12.5.2.1, 9.4.5, 9.4.5.1		
AM-05	Asset Management	Inventory Labels	Organization assets are labeled and have designated owners.		X	X	X			X		X			X	X	X		X	X	X	X	X	X		AM-01 AM-06	1.1	8.1.4.2			8 9 10 26 92 93 80			5.13				CM-08	CM-08	CM-08		ISM-0294 ISM-1217 ISM-0332 ISM-0325 ISM-0330 ISM-0831 ISM-0378 ISM-1187 ISM-1071 ISM-1525	8.1.2.1 8.1.2.2 8.1.2.3 8.1.2.4 8.1.2.5 8.1.2.6	3.3	9.4.2	3.1.1	CC6.1
AM-06	Asset Management	Media Marking	Where applicable, Organization marks information system media indicating the distribution limitations, handling caveats, and applicable security markings (if any) of the information. Exemptions must be approved by management and remain in a specific controlled area.				X					X					X		X	X		X						8.1.10.3					5.1 7.8						MP-03		ISM-1574 ISM-1599 ISM-0323 ISM-0037 ISM-0325 ISM-0330 ISM-0831 ISM-0270	18.1.3.2 18.1.3.4 18.1.3.5 18.1.3.7		9.4		
AM-07	Asset Management	Asset Transportation Authorization	Organization authorizes and records the entry and exit of systems at datacenter locations.	X						X		X		X	X	X	X	X	X	X		X		X	ID.AM-4 PR.DS-3					57 68 69 84			7.1		A.10.4	MA-02 PE-08	MA-02 PE-08	MA-02 PE-08 SA-09 (05)	164.310(d)(1) 164.310(d)(2)(iii)	ISM-1243 ISM-1779	6.1.2.2 8.3.1.2 11.2.5.1 11.2.5.2 11.2.5.3 11.2.5.4 11.2.6.2		9.4.4		CC6.7
AM-08	Asset Management	Asset Transportation Documentation	Organization documents the transportation of physical media outside of datacenters. Physical media is packaged securely and transported in a secure, traceable manner.				X			X				X	X	X	X		X	X		X						8.1.10.3 8.1.10.4				57 68 69					A.10.4	MA-02	MA-02	MA-02 MP-05		ISM-0310	8.3.3.1 8.3.3.2 8.3.3.3 8.3.3.4 8.3.3.5 11.2.5.1 11.2.6.3 11.2.6.5		9.4.3		
AM-09	Asset Management	Use of Portable Media	The use of portable media in Organization datacenters is prohibited unless explicitly authorized by management.												X	X	X					X															MP-07	MP-07	MP-07 MP-05				9.4.4		
AM-10	Asset Management	Maintenance of Assets	Equipment maintenance is documented and approved according to management requirements.	X	X		X			X		X			X	X	X	X	X	X	X	X		X	PR.DS-8 PR.MA-1	PS-06		8.1.10.4 8.1.10.6			13 29			7.13			CM-08 MA-02 MA-04 MP-01 SA-22 SR-11 (02)	CM-08 MA-02 MA-04 MP-01 SA-22 SR-11 (02)	CM-08 MA-02 MA-04 MP-01 MA-03	164.310(a)(2)(iv)	ISM-0305 ISM-0307 ISM-0306 ISM-1598	6.1.1.5 8.3.1.4 8.3.1.5 8.3.1.6 8.3.1.9 11.2.1.10 11.2.4.1 11.2.4.2 11.2.4.3 11.2.4.4 11.2.4.5 11.2.4.6 11.2.4.7 11.2.4.8 11.2.4.9 11.2.4.10 11.2.4.11	7.3	9.4.4		A1.2
AM-11	Asset Management	Tampering of Payment Card Capture Devices	Devices that physically capture payment card data are inspected for evidence of tampering on a semi-annual basis.																			X																						9.5.1.2		
AM-12	Asset Management	Component Installation Inspection and Approval	Prior to installation in a production network, hardware components are inspected for improper or unauthorized modifications.		X	X										X	X		X			X				AM-03	4.2										SR-11 SR-11 (01)	MA-03 (02)		ISM-1418 ISM-0343			2.2, 6.5.1		
AM-13	Asset Management	Software bill of Material	Organization maintains a comprehensive software bill of materials																X																										
BC-01	Business Continuity	Business Continuity Plan	Organization's business contingency plan is periodically reviewed, approved by management and communicated to relevant team members.	X	X		X	X		X					X	X	X	X		X	X		X	X	RC.IM-2	BCM-01 BCM-02 BCM-03 BCM-04		8.1.10.13	4.4 5.1(a) 5.1(b) 5.1€ 5.1(g) 6.2.1(a) 6.2.1(e) 6.3(a) 6.3(b) 7.5.1(a) 7.5.1(b) 8.1© 8.2.1(b)			42 43 44 70						CP-01 CP-02	CP-01 CP-02	CP-01 CP-02 CP-02 (01)	164.308(a)(7)(i) 164.308(a)(7)(ii)(B) 164.308(a)(7)(ii)(D)		17.1.1.1 17.1.1.3 17.1.2.1 17.1.2.3 17.1.2.4 17.1.2.5 17.1.3.4	8.2		5.1.1	CC7.5
BC-02	Business Continuity	Business Continuity Plan: Personal Health Information	Organization's Business Contingency Plan addresses how to access facilities and obtain data during an emergency.				X											X										8.1.10.13													164.310(a)(2)(i) 164.312(a)(2)(ii)					
BC-03	Business Continuity	Business Continuity Plan: Roles and Responsibilities	Business contingency roles and responsibilities are assigned to individuals and their contact information is communicated to authorized personnel.					X									X												4.2.1(a) 4.2.1(b) 5.1© 5.1(f) 5.1(h) 5.3(a) 5.3(b) 6.2.2© 6.3(d) 7.) 7.1(b) 7.1(d)									CP-01 CP-02 IA-02	CP-01 CP-02 IA-02	CP-01 CP-02 IA-02					10.7.3		
BC-04	Business Continuity	Continuity Testing	Organization performs business contingency and disaster recovery tests on a periodic basis and ensures the following: - tests are executed with relevant contingency teams - test results are documented - corrective actions are taken for exceptions noted - plans are updated based on results	X	X		X	X		X		X			X	X	X	X		X	X	X	X	X	RC.IM-2 PR.IP-9 PR.IP-10 ID.SC-5 PR.PT-5	BCM-01 BCM-02 BCM-03 BCM-04 OPS-08 PS-02		8.1.10.12 8.1.10.13	6.2.1(b) 8.4.5 8.5 8.5(a) 8.5(b) 8.5© 8.5(d) 8.5€ 8.5(f) 8.5(g) 8.6(b)			42 44 45 70			5.3			CP-04	CP-04	CP-04 CP-04 (01)	164.308(a)(7)(i)(B) 164.308(a)(7)(ii) 164.308(a)(7)(ii)(D) 164.310(a)(2)(i)		17.1.1.4 17.1.2.4 17.1.3.1 17.1.3.2 17.1.3.3	8.2 8.3	10.7.3	5.2.1 5.2.2	CC7.5 A1.3
BC-05	Business Continuity	Business Impact Analysis	Organization identifies the business impact of relevant threats to assets, infrastructure, and resources that support critical business functions. Recovery objectives are established for critical business functions.	X	X		X			X		X			X	X	X	X	X	X	X	X		X	ID.BE-5 PR.IP-9	BCM-02 BCM-03 BCM-04 OPS-08			3.1 4.3.1(a) 4.3.1(b) 4.3.1© 4.3.2(a) 4.3.2(b) 6.2.1© 6.2.1(d) 6.2.1€ 6.2.1(f) 6.2.1 6.2.2(a) 6.2.2(b)			42 43 70			5.29			CP-09	CP-09	CP-09 CP-02 (08) CP-07 (03)	164.308(a)(7)(ii)(E)	ISM-0246	12.2.1.10 12.2.1.11 17.1.2 17.1.2.2	8.2	10.7.3		CC7.5
BC-06	Business Continuity	Capacity Forecasting	Budgets for infrastructure capacity are established based on analysis of historical business activity and growth projections; purchases are made against the established budget and plans are updated on a quarterly basis.		X			X		X		X					X	X		X	X			X		BCM-01 OPS-01					42 70			8.6					CA-02 (03)	164.308(a)(7)(i)(C)		12.1.3.8	8.1			CC3.1 A1.1
BM-01	Backup Management	Backup Configuration	Organization configures redundant systems or performs periodic backups of data to resume system operations in the event of a system failure.	X	X	X	X					X		X	X	X	X	X	X	X	X	X	X	X	PR.IP-4	OPS-06 OPS-07 PS-02	11.2	8.1.2.1 8.1.4.9 8.1.5.1 8.1.10.11 8.2.4.6 (a) 8.2.4.6 (b)						5.33 8.13 8.14		A.10.3	CP-09 CP-10	CP-09 CP-10	CP-09 CP-10 CP-02 (03) CP-06 CP-07 CP-09 (03)	164.308(a)(7)(i)(A) 164.308(a)(7)(ii)(B) 164.310(d)(2)(iv)	ISM-1547 ISM-1511	8.3.1.7 17.2.1.1 14.1.2.15	8.1 8.4	10.7.3	5.1.1 5.2.1	CC7.5 CC9.1 A1.2 C1.1
BM-02	Backup Management	Resilience Testing	Organization performs annual backup restoration or data replication tests to confirm the reliability and integrity of system backups or recovery operations.	X	X	X	X			X		X		X	X	X	X	X	X	X	X	X	X	X	PR.IP-4	OPS-06 OPS-08 OPS-09 PS-02	11.1 11.3 11.5	8.1.4.9 8.1.10.11			100			8.13		A.10.3	CP-10	CP-10	CP-10 CM-02 (02) CP-06 CP-07 CP-09 (05)	164.308(a)(7)(i)(A) 164.308(a)(7)(ii)(B) 164.310(d)(2)(iv)	ISM-1548 ISM-1511 ISM-1515 ISM-0455	12.3.1.1 12.3.1.2 12.3.1.3 12.3.1.4 12.3.1.5 12.3.1.6 12.3.1.7 12.3.1.8 12.3.1.9 12.3.1.10 12.3.1.11 12.3.1.13 12.3.1.14	8.4	10.7.3	5.2.1 5.2.2	CC7.5 CC9.1 A1.2 A1.3 C1.1
BM-03	Backup Management	Backup Failure Review	Failed backup jobs are periodically reviewed and resolved in a timely manner.		X	X	X													X		X				OPS-06	11.1 11.5	8.1.10.11													12.3.1.12			10.7.3		
BM-04	Backup Management	Alternate Storage	Organization backups are securely stored in an alternate location from source data.			X											X			X				X			11.4											CP-06 (01) CP-07 (01) SA-09 (05)			14.1.3.5			5.2.1	
BM-05	Backup Management	Alternate Telecommunication	Alternate telecommunication service agreements have been established to resume business when the primary service gets disrupted. Service agreements contain priority of service provisions.														X																					CP-07 (03) CP-08 (01) CP-08 (02)							

CFM-01	Configuration Management	Baseline Configuration Standard	Organization ensures security hardening and baseline configuration standards have been established according to industry standards and are reviewed and updated periodically.	X	X	X	X		X		X	X		X	X	X	X	X	X	X	X	X	DE.AE-1 PR.IP-1 PR.PT-3	AM-03 COS-03 OPS-04 OPS-05 OPS-23 PSS-11	4.1 4.2 16.7	8.1.3.2 8.1.5.1 8.1.10.6 8.1.10.8 8.2.4.4			4 13 88 89 90		8.9	CLD.9.5.2		CA-03 CM-01 CM-02 CM-06	CA-03 CM-01 CM-02 CM-06 PL-10 PL-11	CA-03 CM-01 CM-02 CM-06 CM-02 (05) SA-10	164.308(a)(5)(i)(B)	ISM-0299 ISM-1743 ISM-1744 ISM-1408 ISM-1406 ISM-1409 ISM-1654 ISM-1655 ISM-1492 ISM-0843 ISM-1490 ISM-1656 ISM-1657 ISM-1658 ISM-1582 ISM-1392 ISM-1746 ISM-1544 ISM-1659 ISM-0846 ISM-1621 ISM-1622 ISM-1623 ISM-1624	9.5.2.1 PR 12.5.1.7	7.2 11.3 12.2	1.2, 1.2.1, 1.2.2, 2.2.1	8.1.1	CC6.8 CC7.1 CC8.1
CFM-02	Configuration Management	Default "Deny-all" Settings	Where applicable, the information system default access configurations are set to "deny all."			X	X		X								X		X			X				4.5	8.1.3.2		Firewalls									AU-09 (04)		ISM-1654 ISM-1655 ISM-1492 ISM-0843 ISM-1490 ISM-1656 ISM-1657 ISM-1658 ISM-1582 ISM-1392 ISM-1746 ISM-1544 ISM-1659 ISM-0846 ISM-1621 ISM-1622 ISM-1623 ISM-1624 ISM-1486 ISM-1485 ISM-1666 ISM-1668 ISM-1670 ISM-1601			2.2.6, 7.3.3		
CFM-03	Configuration Management	Remote Access Prohibited Protocols and Commands	Organization defines a listing of prohibited user commands and prohibited protocols that can be used in a remote session.			X								X	X	X				X					13.5									AC-17	AC-17	AC-17 AC-17 (04) AU-09 (04)					1.2.5, 1.2.6, 2.2.4, 2.2.5, A2.1, A2.1, 21.2		
CFM-04	Configuration Management	Data Execution Prevention	Organization ensures data execution prevention (DEP) security features are enabled on production hosts to restrict code execution within memory.			X										X				X					10.5											CM-07 (02) SI-16					2.2.6		
CFM-05	Configuration Management	Client Run Time Technologies	Organization disables prohibited client run time technologies on information systems.			X										X				X					9.4											CA-03 (05)					1.2.5, 1.2.6, 2.2.4, 2.2.5		
CFM-06	Configuration Management	Prohibited Activity Monitoring	Organization information systems are configured to explicitly deny a predefined list of activities.														X		X			X															AU-09 (04) CA-03 (05)		ISM-1654 ISM-1655 ISM-1492 ISM-0843 ISM-1490 ISM-1656 ISM-1657 ISM-1658 ISM-1582 ISM-1392 ISM-1746 ISM-1544 ISM-1659 ISM-0846 ISM-1621 ISM-1622 ISM-1623 ISM-1624 ISM-1486 ISM-1485 ISM-1666 ISM-1668 ISM-1670 ISM-1601			1.2.5, 1.2.6, 2.2.4, 2.2.5		
CFM-07	Configuration Management	Configuration Checks	Organization uses mechanisms to detect deviations from baseline configurations on production environments.		X		X		X		X			X	X	X	X			X	X		X	AM-03 COS-03 OIS-04 OPS-04 OPS-05 OPS-23		8.2.4.4			4 13 15 88 89 90		8.18			CM-06 CM-07	CM-06 CM-07	CM-06 CM-07 CM-06 (01) CM-09 SA-10	164.308(a)(5)(i)(B)			7.2 11.3 12.2	11.6, 11.6.1		CC6.8 CC7.1
CFM-08	Configuration Management	Configuration Check Reconciliation Logging	Organization reconciles the established device inventory against the enterprise log repository on a quarterly basis; devices which do not forward security configurations are remediated.				X													X						8.1.10.6																10.4.10.4.1, 10.4.11, 10.4.2, 10.4.2.1		
CFM-09	Configuration Management	Time Clock Synchronization	Systems are configured to synchronize information system time clocks based on International Atomic Time or Coordinated Universal Time (UTC).			X			X		X					X	X	X	X						8.4				13 37		8.17					AC-21			12.4.4.1 12.4.4.2 12.4.4.3 12.4.4.4 PR			10.6, 10.6.1, 10.6.2, 10.6.3	9.1.1	
CFM-10	Configuration Management	Time Clock Configuration Access	Access to modify time data is restricted to authorized personnel.														X			X																SA-10						10.6.3		
CFM-11	Configuration Management	Default Device Passwords	Vendor-supplied default passwords are changed according to Organization standards prior to device installation on the Organization network or immediately after software or operating system installation.				X	X	X										X	X						8.1.4.2 8.1.10.9		Firewalls Secure Configuration	13										ISM-1260 ISM-1304 ISM-1316			2.2.2		
CFM-12	Configuration Management	Process Isolation	Organization implements only one primary function per server within the production environment; the information system maintains a separate execution domain for each executing process.			X			X								X		X	X					12.8				13							AC-04 (21) SC-02		ISM-1750 ISM-1381 ISM-0385 ISM-1479			2.2.2, 8.2.2		
CFM-13	Configuration Management	Collaborative Devices	Where applicable, collaborative computing devices used at Organization are configured to restrict remote activation and provide an explicit indication that they are in use.			X			X						X	X				X					12.8				13						SC-15	SC-15					8.2.2, 8.2.5		
CFM-14	Configuration Management	Software Installation	Installation of software or programs in the production environment is approved by authorized personnel.			X	X		X		X			X	X	X			X	X	X				2.4 2.5 2.6	8.1.4.4 8.1.10.6 8.3.3.2		Malware protection					8.19			CM-11	CM-11	CM-11		ISM-1584 ISM-1491 ISM-1592 ISM-0382	9.4.4.2 9.4.4.4 9.4.4.5 9.4.4.8 12.5.1.12 12.5.1.13 12.6.2.1 12.6.2.3			2.2.4, 6.3.3		
CFM-15	Configuration Management	Job Schedules	Schedule changes or the modifications of production jobs require: - documented approval from authorized personnel - documented monitoring details																X			X																	ISM-1211			6.5, 6.5.1		
CHM-01	Change Management	Change Management Workflow	Change scope, change type, and roles and responsibilities are pre-established and documented in a change control workflow; notification and approval requirements are also pre-established based on risk associated with change scope and type.	X	X		X		X		X			X	X	X			X	X	X	X	PR.IP-3	DEV-01 DEV-03 DEV-05 DEV-07		8.1.7.3 8.1.10.10			30 87		8.32			SA-03	SA-03 CM-05	SA-03 CM-03 CM-03 (05) SA-10			4.5.4.4 12.1.2.1 12.1.2.2 12.1.2.3 12.1.2.4 12.1.2.5 12.1.2.6 12.1.2.7 12.1.2.8 12.1.2.9 14.2.2.1 14.2.2.2 14.2.2.3 14.2.2.4 14.2.2.5 14.2.2.6 14.2.2.7 14.2.2.8 14.2.2.9 14.2.2.10 14.2.2.11 14.2.2.12 14.2.2.13 14.2.2.15	5.4 7.5	6.5, 6.5.1	3.2.1 8.1.1	CC8.1
CHM-02	Change Management	Change Approval	Prior to introducing changes into the production environment, approval from authorized personnel is required based on the following: - change description - impact of change - test results - back-out plan		X		X		X		X	X		X	X	X			X	X	X	X		AM-03 DEV-05 DEV-06 DEV-07 DEV-09 OIS-04 PSS-02 PSS-09		8.1.9.4			30 88 89 90		8.3	CLD.12.1.5		CM-04 CM-06	CM-04 CM-06	CM-04 CM-06 CM-03 SA-10			12.1.2.1 12.1.2.2 12.1.2.3 12.1.2.4 12.1.2.5 12.1.2.6 12.1.2.7 12.1.2.8 12.1.2.10 12.5.1.3 12.5.1.4 12.5.1.5 12.5.1.6 12.6.1.8 12.5.1.10 14.2.3.1 14.2.3.2 14.2.3.3 14.2.4.10 14.2.8.1 14.2.8.3 14.2.9.1 14.2.9.2 6.4.6.1.8	5.5 5.7 5.8 6.3 7.4 7.5	6.5.1	3.2.1	CC8.1
CHM-03	Change Management	Segregation of Duties	Changes to the production environment are implemented by authorized personnel.	X	X				X					X		X			X	X	X	X	PR.AC-4	DEV-07 OIS-04				2 4 5 16 87					CM-05		CM-03 CM-05 (05) SA-10			6.1.2.2 12.5.1.1 14.2.6.11 14.2.6.12	6.3 7.6	6.5.4	2.1.2	CC6.1
CHM-04	Change Management	Communication of Maintenance and Downtime	Customer-impacting product and system changes are publicly communicated on the company website.										X						X		X	X									CLD.12.4.5								12.1.2.11 PR 12.5.1.1 PR				3.2.1	CC2.3
CMS-01	Customer Managed Security	Customer Administrative Access	For products that enable customers to manage their end users, privileged user roles exist with the capability to manage end user access to the relevant applications.		X																			PSS-05 PSS-08																				
CMS-02	Customer Managed Security	Customer Authentication	Authentication to organization customer-facing applications are performed through secure log-on procedures.		X																X			PSS-05																		7.3.1	
CMS-03	Customer Managed Security	Customer Systems Monitoring	As necessary, event logs are made available to customers.		X																			OPS-03																			
CMS-04	Customer Managed Security	Customer Security Engagements	Organization supports customer-requested security inquiries, questionnaires, and audits: - in accordance with customer contracts and agreements - to facilitate due diligence prior to licensing organization products																		X																							
CRY-01	Cryptography	Encryption Key Maintenance	Cryptographic keys are invalidated when compromised or at the end of their defined lifecycle period.						X							X	X	X		X	X	X						24 25 38 39 94					PS-05 SC-12	PS-05	PS-05		ISM-1611 ISM-1612 ISM-1614 ISM-1615 ISM-1095	18.1.5.2 9.3.1.3 10.1.1.4		3.7.4, 3.7.5	10.2.2	
CRY-02	Cryptography	Encryption Key Distribution	Organization prohibits the distribution of cryptographic keys in clear text.														X			X	X													SC-12						9.4.2.1.4 6.4.3.2			3.7.6		
CRY-03	Cryptography	Encryption Key Storage	Encryption keys are securely stored in an approved encryption platform.																	X																						3.7.3		
CRY-04	Cryptography	Clear Text Key Management	If applicable, manual clear-text cryptographic key-management operations must be managed using split knowledge and dual control.																	X																						3.7.6		
CRY-05	Cryptography	Encryption of Data in Transit	Organization restricted data that is transmitted over public networks is encrypted.	X	X	X	X		X					X	X	X	X	X	X	X	X	X	PR.DS-2 PR.DS-5	COS-08 CRY-01 CRY-02 OPS-14 PI-01	3.10	8.1.4.8 8.1.5.4 8.2.4.5 (e)			24 25 73 74 75 76 77 91 94 95 96 97				A11.2	IA-05 (01) IA-07	IA-05 (01) IA-07 SC-08 SC-08 (01)	IA-05 (01) IA-07	164.312(a)(2)(i) 164.312(a)(2)(iv) 164.312(c)(1) 164.312(e)(1) 164.312(e)(2)(i) 164.312(e)(2)(ii)	ISM-1059 ISM-1552 ISM-1277 ISM-0575 ISM-0572 ISM-1589 ISM-1781 ISM-0457 ISM-0469 ISM-0465 ISM-0467 ISM-0263 ISM-0958 ISM-1293	10.1.1.1 13.2.1.1 13.2.1.3 13.2.1.4 13.2.1.6 13.2.3.1 14.1.1.1 14.1.2.4 14.1.2.5 14.1.2.6 14.1.2.7 14.1.2.8 14.1.2.9 14.1.2.10 14.1.2.11 14.1.3.1 14.1.3.2 14.1.3.3 14.1.3.4 18.1.5.1 10.1.1.5 10.1.1.7 13.2.3.2 13.2.1.8	11.1	4.2	10.2.1	CC6.1 CC6.7

CRY-06	Cryptography	Encryption of Data at Rest	Organization restricted data at rest is encrypted.		X	X	X			X						X	X	X	X	X	X	X	X	X			COS-08 CRY-01 CRY-03 PSS-07	3.11 11.3	8.1.4.8			4 24 25 73 74 91 94 95 96 97		5.12				SC-28 SC-28 (01)	SC-28 SC-28 (01)	164.312(a)(2)(iv) 164.312(c)(1) 164.312(e)(2)(ii)	ISM-1597 ISM-1402 ISM-1080 ISM-0457 ISM-0460 ISM-0469	8.4 11.1	3.3.2, 3.5, 3.5.1, 3.5.11	10.2.1	CC6.1 CC6.7
CRY-07	Cryptography	Approved Cryptographic Technology	Where applicable, strong industry standard cryptographic ciphers and keys with an effective strength greater than 112 bits are required for cryptographic security operations.		X	X	X			X		X				X			X	X		X					CRY-02 CRY-04 IDM-08	3.11	8.1.2.2 8.1.9.3 8.1.10.9 8.2.4.4			82		8.24				SC-12 SC-13			ISM-0955 ISM-1597 ISM-1402 ISM-1552 ISM-0457 ISM-0994 ISM-0472 ISM-1446 ISM-0474 ISM-1761 ISM-1762 ISM-0475 ISM-1763 ISM-1764 ISM-0476 ISM-1765 ISM-1766 ISM-1767 ISM-1768 ISM-1769 ISM-1770 ISM-0479 ISM-0481 ISM-1139	10.1.6 13.2.3.4 10.1.5 10.1.7 10.1.8 10.1.2.2 18.1.5.3 18.1.5.4 18.1.5.5		4.2.1, A3.2.6		
CRY-08	Cryptography	Key Repository Access	Access to the cryptographic keystores is limited to authorized personnel.		X					X		X			X			X		X	X	X	X	X			CRY-01 CRY-03 CRY-04					24 25 38 39 94 95 96 97		8.24				SC-12		164.308(a)(3)(ii)(B)		9.2.4.1 10.1.2 10.1.2.1 10.1.2.3 10.1.2.4 10.1.2.5 10.1.2.6 10.1.2.7 10.1.2.8 10.1.2.9 10.1.2.10 10.1.2.11 10.1.2.12 10.1.2.13 10.1.2.14 10.1.2.15 10.1.2.16 10.1.2.17 10.1.2.18 18.1.1.3	9.2 10.2	3.7.1, 3.7.2, 3.7.3	10.2.2	CC6.1
CRY-09	Cryptography	Key Store Review	Management reviews and authorizes key store locations.											X					X		X																						9.4.1.8		3.7.3		
CRY-10	Cryptography	Full Disk Encryption Access	Where full disk encryption is used, logical access must be managed independently of operating system authentication; decryption keys must not be associated with user accounts.														X				X																											
CRY-11	Cryptography	Key Custodians Agreement	Cryptographic Key Custodians and Cryptographic Materials Custodians (CMC) acknowledge in writing or electronically that they understand and accept their cryptographic-key-custodian responsibilities.															X	X	X																						ISM-0507	6.1.1.13.PR		3.6.1		
CRY-12	Cryptography	Approved Certificate Authorities	Organization restricts the use of digital certificates to those that are signed by approved certificate authorities; a certification-path to an accepted trust anchor is established.				X										X		X	X	X																			IA-05 (02)		ISM-1471 ISM-1674 ISM-1675 ISM-1676 ISM-1324 ISM-1323 ISM-1327	14.1.3.6		4.2.1, 4.2.1.1, 8.3.11		
CRY-13	Cryptography	Installation of Software: Certificate Verification	Digital Certificates are verified by information system components prior to installation on the production network.											X	X	X		X	X		X																			CM-11	CM-11	CM-11		ISM-1674 ISM-1675 ISM-1676	14.1.3.6		4.2.1, 4.2.1.1, 8.3.11		
CRY-14	Cryptography	Public Key Infrastructure-based Authentication	Information systems are configured to follow an established certification path to an accepted trust anchor, in the case of network failure, a local cache of revocation data is maintained to support validation.														X		X		X																					IA-05 (02)		ISM-1324 ISM-1323 ISM-1327			4.2.1, 4.2.1.1, 8.3.11		
CRY-15	Cryptography	Software Signing	Organization uses a software signing infrastructure to restrict access to organization's code signing private keys used to sign organization authorized software builds.			X						X																2.7					8.24												
DM-01	Data Management	Data Classification Criteria	Organization's data classification criteria are periodically reviewed, approved by management, and communicated to authorized personnel; the data security management team determines the treatment of data according to its designated data classification level.	X	X	X	X			X		X		X	X	X	X	X	X	X	X	X	X	X	ID.AM-5	AM-06 CRY-01 OPS-11 OPS-12	3.1 3.7	8.1.9.1 8.1.10.2			4 91 92 93		5.12		A.10.12 A.10.2 A.10.4 A.10.5 A.10.6 A.10.7 A.11.2	MP-06 RA-02 SI-12	MP-06 RA-02 SI-12	MP-06 RA-02 SI-12	164.308(a)(7)(i)	ISM-0810 ISM-1083 ISM-0393 ISM-0462	3.3 11.1	3.2.1	3.1.1 10.1.1	CC3.2 CC6.1 CC6.5 C1.1
DM-02	Data Management	Data Inventory	Organization should identify, label and classify Data based on the Data Classification Criteria.	X	X	X	X			X		X		X	X	X	X	X	X	X	X	X	X	X	ID.AM-5	AM-06 CRY-01 OPS-11 OPS-12	3.1 3.7	8.1.9.1 8.1.10.2			4 91 92 93		5.12		A.10.12 A.10.2 A.10.4 A.10.5 A.10.6 A.10.7 A.11.2	MP-06 RA-02 SI-12	MP-06 RA-02 SI-12	MP-06 RA-02 SI-12	164.308(a)(7)(i)	ISM-0810 ISM-1083 ISM-0393 ISM-0462	3.3 11.1	3.2.1	3.1.1 10.1.1	CC3.2 CC6.1 CC6.5 C1.1
DM-03	Data Management	Terms of Service	Consent is obtained for Organization's Terms of Service (ToS) prior to collecting personal information and when the ToS is updated.				X											X			X							8.2.4.5													16.1.7.13.PR			10.1.2	
DM-04	Data Management	Personal Information Access Requests	In accordance with Organization policy, upon request, authenticated individuals are provided with a copy of their personal information or disclosures of their personal information in an understandable form and within the defined timeframe.											X							X															A.1.1								10.1.5	
DM-05	Data Management	Personal Information Deletion Requests	In accordance with Organization policy, Organization processes requests for the deletion of personal information.											X							X															A.1.1								10.1.6	
DM-06	Data Management	External Privacy Inquiries	In compliance with Organization policy, Organization reviews privacy-related inquiries, complaints, and disputes.							X																						91														
DM-07	Data Management	Test Data Sanitization	Restricted data is redacted prior to use in a non-production environment.		X					X		X						X	X		X	X				DEV-10					87 88 89 90		8.33							ISM-1420 ISM-1273 ISM-1274	14.3.1.1 12.1.4.9 14.3.1.2 14.3.1.3 14.3.1.4 14.3.1.5 14.3.1.6		6.5.5, 6.5.6	9.1.2	
DM-08	Data Management	Personal Information Updates	Organization allows authenticated users to review and update their personal information.											X																					A.1.1											
DM-09	Data Management	Credit Card Data Restrictions	Organization does not store full track credit card data, credit card authentication information, credit card verification code, or credit personal identification number (PIN) which Organization processes for payment.																		X																							3.3, 3.3.1, 3.3.1.1, 3.3.1.2, 3.3.1.3			
DM-10	Data Management	Primary Account Number Data Restrictions	Organization restricts primary account number (PAN) data such that only the first six and last four digits are displayed; authorized users with a legitimate business need may be provided the full PAN.									X					X				X													8.11										3.4, 3.4.1, 3.4.2		
DM-11	Data Management	Personal Information Inventory	Organization maintains a documented inventory of media containing personal information.			X											X											3.2																		
DM-12	Data Management	Changes to Data at Rest	Organization uses mechanisms to detect direct changes to the integrity of customer data and personal information. Organization takes action to resolve confirmed unauthorized changes to data.			X	X										X				X	X						3.1.2	8.1.4.11 8.2.4.5									SC-04 SI-07					11.6, 11.6.1	8.1.3 10.1.3	
DM-13	Data Management	Data Processing Integrity	System checks are in place to ensure both complete and accurate capture of data in process.			X	X														X							3.1.2	8.1.2.2 8.1.4.4 8.1.4.7 8.2.4.5																	10.1.3	
DM-14	Data Management	Secure Disposal of Media	Organization securely erases media containing decommissioned restricted data and obtains a certificate or log of erasure; media pending erasure are stored within a secured facility.	X	X	X	X			X		X			X	X	X	X	X	X	X	X	X	X	PR.IP-6	AM-01 AM-04	3.5	8.1.4.10 8.1.10.4 8.2.4.7			85 86		7.14 8.10				MA-02 MP-06	MA-02 MP-06 SR-12	MA-02 MP-06 MP-04	164.310(d)(2)(i) 164.310(d)(2)(ii)	ISM-1741 ISM-0311 ISM-1742 ISM-1223 ISM-1550 ISM-0316 ISM-1642 ISM-0363 ISM-1361 ISM-0370 ISM-0375 ISM-0372 ISM-0373 ISM-0840 ISM-0374 ISM-0375	8.3.2.1 8.3.2.2 8.3.2.3 8.3.2.4 8.3.2.5 8.3.2.6 8.3.2.7 8.3.2.8 11.2.7.1 11.2.7.2 11.2.7.3 11.2.7.4.PR	11.1	3.2.1, 9.4.6, 9.4.7	8.1.2 11.2.3	CC6.5 C1.2
DM-15	Data Management	Customer Data Retention and Deletion	Organization purges or archives data according to customer requests or legal and regulatory mandates.		X	X				X				X					X	X	X	X	X			PI-03	3.5				99			C.1.D.8.1.5								12.7.1.4 13.2.1.7	11.1	3.2.1, 9.4.6, 9.4.7	10.1.1	C1.1 C1.2
DM-16	Data Management	Removal of PHI from Media	Organization removes electronic protected health information from electronic media if the media is made available for re-use.																																					164.310(d)(2)(ii)						
DM-17	Data Management	Secure Disposal of Media: Testing	Organization tests sanitization procedures and equipment annually for effectiveness.												X	X	X		X																		MP-06	MP-06 SR-12	MP-06		ISM-0313 ISM-1741 ISM-0311 ISM-1742 ISM-1223 ISM-1550 ISM-0316 ISM-1600 ISM-0947 ISM-0348 ISM-0351 ISM-1795 ISM-0368 ISM-0370 ISM-0371 ISM-0372 ISM-0373 ISM-0374 ISM-0375						
DM-18	Data Management	Personal Information Retention and Deletion	Organization retains and deletes personal information from Organization and service provider systems in accordance with Organization policy.			X								X					X		X							3.4 15.7								A.9.3						12.3.1.5.1 18.1.3.8 18.1.3.9 18.1.3.10 18.1.3.11			8.1.2 10.1.6	
DM-19	Data Management	Temporary Storage of Personal Information	Temporary files and documents containing personal information are deleted in accordance with a timeframe consistent with Organization policy.											X																					A.4.1						ISM-1245					
DM-20	Data Management	Social Media	Sharing Organization restricted data via messaging technologies, social media, and public websites is prohibited.													X	X		X	X		X																PL-04 (01)	PL-04 (01)		ISM-0820 ISM-1146	8.3.1.10 14.1.1.10		4.2.2		
DM-21	Data Management	Publicly Accessible Content	Organization protects its public information system presence with the following processes: only authorized and trained individuals may post public information, content is reviewed prior to publishing, information on public systems is reviewed periodically, and non-public information is removed from public systems upon discovery.													X	X		X																		AC-22 PL-04 (01)	AC-22 IR-09 (02)		ISM-1146 ISM-0821 ISM-0824					
DM-22	Data Management	Data Loss Prevention	Data loss prevention capabilities are implemented to protect sensitive information as it is stored, transmitted, and processed.			X																X						3.13																	10.1.4	
EM-01	Entity Management	Board of Directors Structure and Purpose	The Board of Directors provides corporate oversight, strategic direction, and review of management for Organization. The Board of Directors meets at least quarterly and has 3 sub-committees: - Audit Committee - Executive Compensation and Nominating Committee - Governance Committee					X			X									X			X							4.1			5.1											3.1			CC1.1

EM-02	Entity Management	Audit Committee	The Audit Committee is governed by a Charter, is independent from Organization Management, composed of outside directors (Industry Experts), and meets quarterly. The Audit Committee oversees: -Financial Statement Quality -Enterprise Risk Management -Regulatory & Legal Compliance -Internal Audit Functions -Information Security Functions -External Audit Functions				X	X			X	X							X	X			X			8.1.7.4	4.1 4.2.2(a) 4.2.2(b)			5.1 5.3	5.31								3.1.4.2 3.1.5.1 4.4.2.1 6.1.4.1 6.1.4.2 6.1.4.3 6.1.4.4 6.1.4.5 6.1.4.6 18.1.1.1 18.1.1.2 18.1.1.3 18.1.1.5.P	3.1			CC1.2
EM-03	Entity Management	Organizational Structure	Organization Management ensures that its organization is aligned with the corporate strategy by assigning key managers with responsibilities to execute the corporate strategy.								X	X							X										5.1a	5.2								ISM-1407 ISM-0717 ISM-0039				
EM-04	Entity Management	Operating Plans	Annual operating plans are aligned with Corporate Objectives, which are established on an annual basis during the Company's planning process. Priorities are set and plans are communicated appropriately.								X								X										5.1 (a) 7.1									ISM-0724				
EM-05	Entity Management	Cyber Security Insurance	Organization purchases cyber security insurance to mitigate risk of material financial impact that could result from a cyber security event.								X									X	X			X					7.1										4.2.2.18 14.1.2.12 14.1.2.13	4.4			CC9.1
EM-06	Entity Management	Internal Audit Function	Quarterly, the Chief Audit Executive meets with the Audit Committee to review key risk issues. The Audit Committee approves the annual Internal Audit Plan. Results of quarterly audits and subsequent issue tracking summaries are presented to the Audit Committee.								X									X									9.2										3.1.4.1 12.7.1.2 14.1.1.2 18.2.1.7 18.2.1.12.P 18.2.1.13.P 18.2.2.3 18.2.2.4 18.2.2.5 18.2.2.6				
EM-07	Entity Management	Financial Control Review	Internal financial control assessment results are reported to the Audit Committee by the Chief Audit Executive on a quarterly basis and support the CEO/CFO 302/404 certifications.								X																		9.2														
EM-08	Entity Management	Information Security Function	Quarterly, the Chief Security Officer meets with the Audit Committee to review key Information Security issues. Results of continuous monitoring activities and current security compliance status are presented to the Audit Committee and the Board of Directors.				X				X								X	X						8.1.7.4				9.3									ISM-1478	3.1.4.4 3.1.6.1				
EM-09	Entity Management	Information Security Compliance Review	Information Security compliance results are reported to the Audit Committee by the Chief Security Officer on a quarterly basis and support information security compliance certifications.															X				X	X													ALU-07				4.6.2.6 18.2.1.6 18.2.1.8 18.2.2.2	3.1 4.5 15.1		1.3.1	CC4.2
EM-10	Entity Management	Common Controls Framework	Organization maintains a Common Control Framework (CCF) that is used in the implementation of control measures as a risk mitigation strategy to support organization operations, technology infrastructure, and security management activities.																				X																				CC5.1 CC5.2
EM-11	Entity Management	Service Agreement	When customers sign-up for Organization's product and services, the customer is required to acknowledge a service agreement which includes considerations for protecting security, availability, confidentiality and indicates the responsibilities of the users and organization's responsibilities and commitments.		X																		X			COM-01 OIS-02 OIS-03 PI-02																	CC2.3 CC3.1
IAM-01	Identity and Access Management	Logical Access Provisioning	Logical access provisioning to information systems requires approval from appropriate personnel.	X	X	X	X		X	X			X	X	X	X	X	X	X	X	X	X	X	PRAC-1	DEV-07 IDM-01 IDM-02 IDM-06 OIS-04 OPS-16	5.6 6.1 6.7	8.1.3.2 8.1.4.2 8.1.7.3 8.2.3.1 8.2.4.2 (a)		Secure Configuration	2 3 4 14 15 16 17 88 89 90		5.9 5.15		A.10.9	AC-01 AC-02 AC-03 CP-09 IA-04 IA-05 MP-02	AC-01 AC-02 AC-03 CP-09 IA-04 IA-05 CM-05	AC-01 AC-02 AC-03 CP-09 IA-04 IA-05 MP-02 AC-04 (21)	164.308(a)(3)(ii) 164.308(a)(3)(ii)(A) 164.308(a)(3)(ii)(B) 164.308(a)(4)(i) 164.308(a)(4)(ii)(B) 164.308(a)(4)(ii)(C) 164.312(a)(1) 164.312(c)(1)	ISM-1733 ISM-1650 ISM-1681 ISM-1652 ISM-1684 ISM-1655 ISM-1271 ISM-1272	6.1.2.1 9.1.1.1 9.1.1.2 9.1.1.3 9.2.1.1 9.2.1.3 9.2.1.4 9.2.1.5 9.2.2.2 9.2.2.3 9.2.2.4 9.2.2.5 9.2.2.6 9.2.2.7 9.2.6.2 9.2.6.3 9.2.6.4 9.3.1.2 9.4.1.1 9.5.1.1P 12.6.2.4 16.1.1.1	9.1 11.4	7.2, A3.4	2.1.2 7.1.1 8.3.1	CC6.2 CC6.3
IAM-02	Identity and Access Management	Change of Access Notification	Changes made to system access trigger a notification that is sent to designated personnel.			X									X	X	X		X		X	X				3.1.4									**AC-02**	AC-02	AC-02 AC-02 (04)		ISM-1650 ISM-1651 ISM-1652			7.2.3, 8.2.4	7.3.2	
IAM-03	Identity and Access Management	Logical Access De-provisioning	Logical access that is no longer required in the event of a termination is documented, communicated to management, and revoked.	X	X	X	X		X	X					X	X	X	X	X	X	X	X	X	PRAC-1	IDM-01 IDM-02 IDM-03 IDM-04	6.2 15.7	8.1.4.2 8.1.8.4		Secure Configuration User Access Control	2 3 14 15 16 17 60					AC-02 PS-04	AC-02 PS-04	AC-02 PS-04 AC-02 (02)	164.308(a)(3)(ii) 164.308(a)(3)(ii)(B) 164.308(a)(3)(ii)(C) 164.308(a)(4)(i) 164.308(a)(4)(ii)(B) 164.308(a)(4)(ii)(C) 164.312(a)(1) 164.312(c)(1)	ISM-0430 ISM-1595 ISM-1404 ISM-1648 ISM-1796 ISM-1647 ISM-1734	7.3.1.1 7.3.1.2 7.3.1.3 9.2.1.1 9.2.2.1 9.2.6.1 9.2.6.5 9.2.6.6 9.4.1.1 9.5.1.1P	9.1	8.2.4, 8.2.5	2.1.3 7.1.1	CC6.2 CC6.3
IAM-04	Identity and Access Management	Logical Access De-provisioning: Notification	The People Resources system sends a notification to relevant personnel in the event of a termination of an information system user.			X	X								X	X	X			X						6.2	8.1.8.2								PS-04	PS-04	PS-04 AC-02 (02)					8.2.4, 8.2.5		
IAM-05	Identity and Access Management	Logical Access Review	Organization performs account and access reviews on a quarterly basis; corrective action is taken where applicable.		X	X	X		X	X			X		X	X	X	X	X	X	X	X	X		IDM-01 IDM-02 IDM-03 IDM-04 IDM-05 OIS-04 OIS-07	5.1 5.3 5.5 6.8	8.1.3.2 8.1.4.2 8.1.10.6 8.2.3.1 8.2.4.2 (a)		Secure Configuration User Access Control User Access Control	15 17		5.18			IA-05 PS-05	IA-05 PS-05	IA-05 PS-05 AC-02 (03)	164.308(a)(3)(ii) 164.308(a)(3)(ii)(A) 164.308(a)(3)(ii)(B) 164.308(a)(3)(ii)(C) 164.308(a)(4)(i) 164.308(a)(4)(ii)(C) 164.312(a)(1)	ISM-0407 ISM-1610 ISM-1271 ISM-1272	9.2.5.1 9.2.5.3 9.2.5.4 9.2.5.5 9.2.5.6 9.4.1.1 9.4.4.9 11.1.2.1 11.1.2.2 12.5.1.1P	9.1	8.2.6, A3.4.1	7.2.1	CC6.2 CC6.3
IAM-06	Identity and Access Management	Role Change: Access De-provisioning	Upon notification of an employee reassignment or transfer, management reviews the employee's access for appropriateness. Access that is no longer required is revoked and documented.			X	X								X	X	X			X	X					6.2	8.1.10.6								AC-02 PS-05	AC-02 PS-05	AC-02 PS-05					8.2.4	2.1.3	
IAM-07	Identity and Access Management	Shared Logical Accounts	Organization restricts the use of shared and group authentication credentials. Authentication credentials for shared and group accounts are reset every 90 days.		X		X										X	X	X		X		X		CRY-01		8.3.2.3										164.308(a)(5)(ii)(D)	ISM-0415	9.2.4.2 9.2.4.3 9.2.4.4 9.2.4.5 9.2.4.6 9.2.4.7 9.2.4.8 9.3.1.1		8.2.2, 8.2.3, 8.2.6		CC6.1
IAM-08	Identity and Access Management	Shared Logical Accounts: Group Member	Passwords for shared and group accounts are reset when a member of the shared group leaves.																	X																					8.2.2, 8.2.5			
IAM-09	Identity and Access Management	Shared Account Restrictions	Where applicable, the use of generic and shared accounts to administer systems or perform critical functions is prohibited; generic user IDs are disabled or removed.			X											X		X	X		X				4.7										AC-02 (09)		ISM-0380 ISM-0383	9.2.3.9		2.2.2, 8.2.2		
IAM-10	Identity and Access Management	Role Change: People Resources Notification	The People Resources system sends a notification to relevant management and relevant information system administrators in the event of an employee reassignment or transfer of an information system user.			X														X						6.1															7.2.3			
IAM-11	Identity and Access Management	Temporary Account Termination	Temporary and emergency accounts are automatically terminated 90 days from the date they are generated.						X								X		X										Secure Configuration User Access Control								AC-02 (05)		ISM-1610					
IAM-12	Identity and Access Management	Unique Identifiers	Organization requires unique identifiers for user accounts and prevents identifier reuse.		X	X	X			X		X		X	X	X	X	X	X	X	X	X	X		COS-06 IDM-01 OPS-24 PSS-07	3.14	8.1.4.1			15 17 21 22 23 24 25		5.16		A.10.8 A.10.10	AC-02 IA-04 IA-05 IA-08	AC-02 IA-04 IA-05 IA-08	AC-02 IA-04 IA-05 IA-08 IA-03 IA-04 (04)	164.312(a)(1) 164.312(a)(2)(i) 164.312(d)	ISM-0414 ISM-1583 ISM-1685 ISM-1262	9.4.1.1 9.4.1.2 9.4.1.3 9.4.1.4 9.4.1.5 9.4.1.6 9.4.1.7 9.4.2.1	9.1	8.2.1		CC6.1
IAM-13	Identity and Access Management	Password Authentication	User and device authentication to privileged information systems is protected by passwords that meet Organization's password complexity requirements.		X		X		X	X		X			X	X	X	X		X	X	X	X		COS-05 IDM-01 IDM-08 IDM-09 PSS-07		8.1.10.9		Secure Configurations User Access Control	15 17 18 19 20 21 22 23 24 25		5.17 8.5			AC-14 IA-05 (01)	AC-14 IA-05 (01) IA-02 (08)	AC-14 IA-05 (01)	164.308(a)(5)(ii)(D) 164.312(d)		9.4.2.3 9.4.2.5 9.4.2.6 9.4.2.7 9.4.2.8 9.4.2.10 9.4.3.1 9.4.3.2 9.4.3.3 9.4.3.4 9.4.3.5 9.4.3.6 9.4.3.7	9.1 9.3	8.3.5, 8.3.6, 8.3.9	7.3.2 10.2.1	CC6.1
IAM-14	Identity and Access Management	Multifactor Authentication	Multi-factor authentication is required for: - remote VPN sessions - access to trusted data environments	X	X	X	X			X					X	X	X	X	X	X	X	X	X	PRAC-7	COS-02 COS-04 COS-05 COS-08 IDM-01 IDM-08 IDM-09 OPS-14 OPS-16	5.2 6.3 6.4 6.5 13.5	8.1.4.1 8.2.4.1			15 17 21 22 23 24 25 57 68 69					AC-20 IA-02 (01) IA-08 MA-04	AC-20 IA-02 (01) IA-02 (12) IA-08 MA-04 IA-02 (02)	AC-20 IA-02 (01) IA-02 (12) IA-08 MA-04 IA-02 (02)	164.312(d)	ISM-0974 ISM-1173 ISM-1504 ISM-1679 ISM-1680 ISM-1681 ISM-1505 ISM-1405 ISM-1682 ISM-1559 ISM-1683 ISM-1684	9.4.2.2.B	9.1 9.3	B.4, B.4.1, B.4.2, B.4.3	7.3.1	CC6.1 CC6.6
IAM-15	Identity and Access Management	Authentication Credential Maintenance	Authorized personnel verify the identity of users before modifying authentication credentials on their behalf.							X					X	X	X		X	X	X									18 19 20					AC-14 IA-05 IA-05 (01)	AC-14 IA-05 IA-05 (01)	AC-14 IA-05 IA-05 (01) IA-03		ISM-1584 ISM-1494 ISM-1592 ISM-0382 ISM-1593	14.1.1.5		8.3.3		
IAM-16	Identity and Access Management	Session Timeout	Information systems are configured to terminate inactive sessions after 15 minutes or when the user terminates the session.		X	X	X		X						X	X	X	X	X	X	X				PSS-06	4.3	8.1.4.1		Secure Configuration						MA-04	MA-04	MA-04 AC-11 AC-12 SC-10 SC-23	164.312(a)(2)(iii)	ISM-1649 ISM-0853 ISM-0428	9.2.1.1 9.2.1.2 9.4.2.5 9.4.2.9a 11.2.8.2 11.2.8.3 11.2.8.4		8.2.8		
IAM-17	Identity and Access Management	Session Limit	Information systems are configured to limit concurrent login sessions and the inactive user interface is not displayed when the session is terminated.		X												X			X					PSS-06													ISM-0853			8.2.8		
IAM-18	Identity and Access Management	Account Lockout: Cardholder Data Environments	Users are locked out of information systems after 6 invalid attempts for a minimum of 30 minutes, or until an administrator enables the user ID.			X	X		X						X	X	X		X	X						4.10	8.1.4.1		Secure Configuration						AC-07	AC-07	AC-07 AC-02 (05)			9.4.2.9		8.3.4		
IAM-19	Identity and Access Management	Account Lockout	Users are locked out of information systems after multiple, consecutive invalid attempts within a defined period; accounts remain locked for a defined period.			X											X		X	X						4.10											AC-02 (05) AC-11		ISM-1403			8.3.4		
IAM-20	Identity and Access Management	Login Banner	Systems leveraged by the U.S. Federal Government present a login screen that displays the following language: - users are accessing a U.S. Government information system - system usage may be monitored, recorded, and subject to audit - unauthorized use of the system is prohibited and subject to criminal and civil penalties - use of the system indicates consent to monitoring and recording														X	X																			AC-08	AC-08								
IAM-21	Identity and Access Management	Credentials Validation	Organization systems utilize Federal Identity, Credential, and Access Management (FICAM) components and conform to FICAM-issued profiles; systems verify and accept the following external credentials: - personal Identity Verification (PIV) credentials from federal agencies, and - FICAM-approved credentials from non-federal third-parties														X																			IA-08 (01) IA-08 (02) IA-08 (04)								
IAM-22	Identity and Access Management	Password Authentication Standard: Federal Systems	Organization information systems obscure feedback of authentication information during the authentication process (e.g., the system does not disclose error information such as "user" is not a valid username") and have the following password requirements: - minimum of 12 characters - contains at least one upper-case letter, lower-case letter, number, and a special character - at least one of the characters is changed when the new passwords are created - the password life span is between 1 to 60 days - password reuse is prohibited for 24 generations - only allow the use of temporary password system logons with an immediate change to a permanent password			X									X	X			X	X						5.2									IA-06	IA-06			ISM-1595 ISM-1590	9.3.1.4				

IAM-23	Identity and Access Management	Privileged Session Management	Privileged logical access to trusted data environments is enabled through an authorized session manager; session user activity is recorded and tunnelling to untrusted data environments is restricted.			X	X					X			X	X	X		X	X	X					3.3 3.14 5.4	8.1.5.1 8.1.5.2 8.1.10.6					8.2			IA-05 IA-08 IA-11	IA-02 (12) IA-05 IA-08 IA-02 (08) IA-11	IA-02 (12) IA-05 IA-08 AC-02 (07) AC-04 (05) AC-06 (09) AC-06 (10) SC-23		ISM-1546 ISM-1599 ISM-1650 ISM-1651 ISM-1652 ISM-1620 ISM-1402 ISM-1385 ISM-1388 ISM-1705 ISM-1706 ISM-1707 ISM-1708 ISM-1429	9.2.3.1 9.2.3.2 9.2.3.3 9.2.3.4 9.2.3.5 9.2.3.6 9.2.3.7 9.2.3.8 9.2.3.10 9.2.3.11PB 14.1.1.c 14.2.6.1		7.2.6	7.1.1 7.2.2	
IAM-24	Identity and Access Management	Zero Trust Enterprise Network	Organization users are authenticated against a Zero Trust model prior to gaining access to organization resources.									X		X																	5.17 5.15		A:1.1														
IAM-25	Identity and Access Management	Logical Access Role Permission Authorization	Initial permission definitions, and changes to permissions, associated with logical access roles are approved by authorized personnel.			X						X			X	X	X		X	X	X	X				6.1 6.8						8.3			AC-02	AC-02	AC-02 AC-05 AC-06 AC-06 (09) AC-06 (02)		ISM-0405 ISM-1507 ISM-1733 ISM-1508 ISM-1175 ISM-1653 ISM-0445 ISM-0441	14.1.2.3		7.2.1	7.2.1 8.1.4	
IAM-26	Identity and Access Management	Source Code Security	Access to modify source code is restricted to authorized personnel.							X		X				X			X	X	X	X							15 87		8.4					AC-06 (10)		ISM-1584 ISM-1491 ISM-1592 ISM-0382	9.4.5.1 14.2.6.2		7.2.1	2.1.2	
IAM-27	Identity and Access Management	Service Account Restrictions	Individual user or administrator use of service accounts for OS, applications, and databases is prohibited.																X		X																		ISM-0549 ISM-1659 ISM-1268			8.2.1		
IAM-28	Identity and Access Management	PCI Account Restrictions	Organization clients with access to the cardholder data environment (CDE), as users or processes, are assigned unique accounts that cannot modify shared binaries or access data, server resources, or scripts owned by another CDE or Organization; application processes are restricted from operating in privileged mode.																		X																							8.2.1		
IAM-29	Identity and Access Management	Least Privilege	Role-based access is defined and deployed to restrict privileged access to information resources based on the concept of least privilege.			X	X					X				X			X	X	X	X				3.3 5.4 6.8 12.2	8.1.4.2 8.1.5.3					5.3					AC-02 (07) AC-06 AC-06 (09) AC-06 (02) AC-06 (05)		ISM-1392 ISM-1746 ISM-0846 ISM-1748 ISM-1489 ISM-1546 ISM-0042 ISM-1380 ISM-1687 ISM-1688 ISM-1689 ISM-1387 ISM-1381 ISM-1705 ISM-1706 ISM-1707 ISM-1708 ISM-1249 ISM-1250 ISM-1263 ISM-1264 ISM-1256 ISM-1255 ISM-1268	9.1.1.16 9.4.2.4 9.4.4.1 9.4.4.3 9.4.4.7 12.6.2.2 16.1.1.5 12.7.1.3 6.1.2.3		7.2.1, 7.2.2, A11, A11.1, A11.2, A1.1.3 8.3.11	2.1.1 7.1.1 7.2.2 10.1.4	
IAM-30	Identity and Access Management	Virtual Private Network	Remote connections to the corporate network are accessed via VPN through managed gateways.		X	X	X			X		X			X	X	X	X	X		X	X		COS-02 COS-04 COS-05 COS-08 IDM-09	12.7 13.5	8.1.4.1				57 68 69	6.7			AC-20 MA-04	AC-20 MA-04	AC-20 MA-04	164.312(a)(2)(iv) 164.312(d)		ISM-1392 ISM-1746 ISM-0846 ISM-1748 ISM-1489 ISM-1546 ISM-0042 ISM-1380 ISM-1687 ISM-1688 ISM-1689 ISM-1381 ISM-1705 ISM-1706 ISM-1707 ISM-1708 ISM-1249 ISM-1250 ISM-1263 ISM-1264 ISM-1256 ISM-1255 ISM-1268 ISM-0681		9.3	12.2.1		CC6.1 CC6.7
IAM-31	Identity and Access Management	Virtual Private Network: Restrict Split-Tunneling	VPN configurations restrict split-tunneling capabilities.																X		X																		ISM-0705			12.2.1		
IAM-32	Identity and Access Management	Ability to Disable Remote Sessions	Organization has a defined process and mechanisms in place to expeditiously disable or disconnect remote access to information systems within a defined time frame based on business need.			X	X												X	X	X					13.5	8.1.10.6												ISM-1439	11.2.1.3		12.2.1		
IAM-33	Identity and Access Management	Remote Maintenance: Authentication Sessions	Vendor accounts used for remote access are enabled only during the time period needed, disabled when not in use, and monitored while in use.			X													X							13.5																	8.2.7		
IAM-34	Identity and Access Management	Remote Maintenance: Unique Authentication Credentials for each Customer	Where applicable, Service providers with remote access to customer premises (e.g., for support of POS systems or servers) must use a unique authentication credential (such as a password/phrase) for each customer.																		X																							8.2.3		
IAM-35	Identity and Access Management	Remote Maintenance: Authentication	Remote maintenance and diagnostic tool utilization are restricted to the minimum required level, strong authentication is required, and remote sessions are recorded.													X					X																MA-03 (03)							8.2.7		
IAM-36	Identity and Access Management	Remote Maintenance: Audit	Organization documents and maintains records for vendor remote maintenance, diagnostic activities, and permissions granted. A listing of vendor remote maintenance connections is documented as well.																		X																							8.2.7		
IAM-37	Identity and Access Management	End-user Environment Segmentation	Where applicable, processes that run as part of an Organization shared hosting platform will run under unique credentials that permit access to only one customer environment.																X	X	X																		ISM-1749	9.4.1.8.PB		8.2.3		
IAM-38	Identity and Access Management	End-user Access to Applications and Data	Organization applications secure user data and maintain confidentiality by default or according to permissions set by the individual. Organization authenticates individuals with unique identifiers and passwords prior to enabling access to: - use the application - view or modify their own data				X		X					X	X				X	X	X				Secure Configuration							CLD.9.5.1	A.1.1 A.10.13					ISM-0843 ISM-1490 ISM-1656 ISM-1657 ISM-1658 ISM-1582 ISM-1392 ISM-1746 ISM-0846	9.2.1.6.PB 9.2.2.8.PB 9.2.4.9.PB 14.1.2.2		8.1.10, 8.1.10.1		
IAM-39	Identity and Access Management	Hardware Tokens	Where applicable, hardware token-based authentication is facilitated only by approved organizations.																		X																							4.2.1, 4.2.1.1, 8.3.11		
IR-01	Incident Response	Incident Response Plan	Organization defines the types of incidents that need to be managed, tracked and reported, including: - procedures for the identification and management of incidents - procedures for the resolution of confirmed incidents - key incident response systems - incident coordination and communication strategy - contact method for internal parties to report incidents - support team contact information - notification to relevant management in the event of a security breach - provisions for updating and communicating the plan - provisions for training of support team - preservation of incident information - management review and approval, annually, or when major changes to the organization occur	X	X	X	X			X		X			X	X	X	X	X	X	X	X	X	IO.RA-4 PR.IP-9 RS.RP-1 RS.CO-3 RS.CO-2 RS.CO-1 RS.AN-4 RS.AN-2 RS.IM-1 RS.MI-1 RC.IM-1 RC.RP-1	COS-01 SIM-01 SIM-05	17.1 17.4 17.8 17.9	8.1.10.12				2 3 32 36 60	5.24 5.27 5.28			IR-04 IR-06 IR-07 IR-08	IR-04 IR-06 IR-07 IR-08 AT-02 (02)	IR-04 IR-06 IR-07 IR-08 IR-04 (01) IR-09 (03)	164.308(a)(6)(i) 164.308(a)(6)(ii)	ISM-0576 ISM-0125 ISM-0133 ISM-1609 ISM-1731 ISM-1732 ISM-0138 ISM-0123 ISM-0141 ISM-0043 ISM-0109 ISM-1228 ISM-0142	4.9.1.1 5.1.1.3.1P 6.1.3.2 16.1.1.1 16.1.1.2 16.1.1.3 16.1.1.4 16.1.1.5 16.1.1.6P 16.1.1.14 16.1.2.1 16.1.4.1 16.1.4.2 16.1.5.1 16.1.5.2 16.1.5.3 16.1.5.4 16.1.5.5 16.1.5.6 16.1.5.7 16.1.5.8 16.1.6.2 16.1.7.1 16.1.7.2	7.7 7.8 12.3	12.10.1	6.1.1 6.2.1	CC7.4 CC7.5
IR-02	Incident Response	Incident Response Testing	Organization tests incident response processes on an annual basis. Results from the tests are documented.		X	X	X									X					X	X															IR-03				12.10.2, 12.10.4, 12.10.4.1	5.1.3	
IR-03	Incident Response	Incident Response	Confirmed incidents are assigned a priority level and managed to resolution. If applicable, Organization coordinates the incident response with business contingency activities.	X	X	X				X		X			X	X	X	X	X	X	X	X	X	DE.DP-3 DE.DP-5 RS.CO-3 RS.CO-4 RS.MI-2 RS.IM-2	COS-01 OPS-20 SIM-01 SIM-02 SIM-03 SIM-05	17.9				2 3 32 36 60	5.25 5.26			IR-04 IR-05	IR-04 IR-05	IR-04 IR-05 IR-09 IR-03 (02)	164.308(a)(6)(i) 164.308(a)(6)(ii)	ISM-0125 ISM-0133 ISM-1609 ISM-1731 ISM-1732 ISM-0138 ISM-0123 ISM-0141	16.1.2.2 16.1.2.3 16.1.2.4 16.1.2.5 16.1.2.6 16.1.2.7 16.1.2.8 16.1.2.9 16.1.2.10 16.1.5.9 16.1.6.1 16.1.7.2	7.7 12.3	12.10.1	5.1.3 6.2.1	CC7.4
IR-04	Incident Response	External Communication of Incidents	Organization defines external communication requirements for incidents, including: - information about external party dependencies - criteria for notification to external parties as required by Organization policy in the event of a security breach - contact information for authorities (e.g., law enforcement, regulatory bodies, etc.) - provisions for updating and communicating external communication requirement changes	X	X	X	X	X		X				X					X	X	X	X	X	X	RC.CO-2	OIS-03 OPS-21 SIM-05	17.2 17.6	8.1.7.4 8.2.6.2	7.4(a)			1 5 32			A.9.1				ISM-1433 ISM-0140	6.1.3.1	12.1 12.3	12.10.1	5.1.1 5.1.2 6.2.1 8.1.3 8.2.1	CC2.3 CC7.4
IR-05	Incident Response	Incident Reporting Contact Information	Organization provides a contact method to: - submit complaints and inquiries - report incidents		X	X				X		X			X	X			X	X		X		OIS-05 SIM-04	17.3					32 60	6.8			IR-06	IR-06	IR-06			16.1.3.2 16.1.2.11.P 16.1.2.12.P	7.7			CC2.3
IR-06	Incident Response	Incident External Communication	Organization communicates a response to external stakeholders as required by the Incident Response Plan.	X	X	X	X							X					X	X	X	X	X	RS.CO-5	OPS-21 SIM-03	17.4 17.6	8.2.6.2							A.9.1						12.6.1.18.PB 16.1.2.13.P	7.7 12.3	12.10.1	5.1.2 6.1.1 6.2.1	CC2.3
IR-07	Incident Response	External Communication of Incidents: Protected Health Information	Organization communicates the discovery and status of the breach of Protected Health Information (PHI) to the covered entity within 60 days or as required by the Business Associates Agreement (BAA) and provides the following information if available: - description of the Event - description of the Information that was compromised - identification of the Individuals whose PHI were compromised - steps Required to Protect Individuals - investigation Plan - contact Information																																										
IR-08	Incident Response	Problem Management	Organization resolves customer support inquiries.																			X																					1.3.1 4.3.1 11.1.2 11.2.2	
MDM-01	Mobile Device Management	Mobile Device Enrollment	Mobile devices (i.e., laptops, smartphones, tablets) must be configured with the appropriate Mobile Device Management (MDM) profile when used as a medium to access Organization internal resources.		X	X	X					X			X	X	X		X	X	X			AM-05	1.1 4.1.1 4.1.2	8.3.3.1 8.3.3.2					8.1			AC-19 MP-07	AC-19 MP-07	AC-19 MP-07		ISM-1533 ISM-1195 ISM-1297 ISM-1082 ISM-0875	6.2.1.1 6.2.1.2 6.2.1.3 6.2.1.4 6.2.1.5 6.2.1.6 6.2.1.7 6.2.1.8 6.2.1.10 6.2.1.11 6.2.1.12 6.2.1.13 6.2.1.16 6.2.1.17 6.2.1.18 6.2.1.19 6.2.1.21 6.2.1.22 11.2.6.1		1.5, 1.5.1, 5.2, 5.2.1, 5.2.2, 5.2.3, 5.2.3.1, 5.3, 5.3.1, 5.3.2, 5.3.2.1, 5.3.3, 5.3.4, 5.3.5		
MDM-02	Mobile Device Management	Mobile Device Encryption	Mobile devices (i.e., laptops, smartphones, tablets) that are used to access data from Organization internal resources are encrypted.			X						X				X			X	X	X				3.6 3.9						8.1					AC-17 (02)		ISM-0869 ISM-1085 ISM-1084	6.2.1.1 6.2.1.2 6.2.1.9 6.2.1.15 10.1.1.3		1.5, 1.5.1, 5.2, 5.2.1, 5.2.2, 5.2.3, 5.2.3.1, 5.3, 5.3.1, 5.3.2, 5.3.2.1, 5.3.3, 5.3.4, 5.3.5		
MDM-03	Mobile Device Management	Configuration Management: Mobile Devices	Organization Mobile devices (i.e., laptops, smartphones, tablets) are configured to ensure unnecessary hardware capabilities and functionalities are disabled, and management defined security features are enabled.			X	X					X			X	X	X		X	X	X				4.3 4.8	8.3.3.2 8.3.4.1					8.1			AC-19	AC-19	AC-19		ISM-1400 ISM-1482 ISM-0863 ISM-0864 ISM-1366 ISM-0870	6.2.1.23		1.5, 1.5.1, 5.2, 5.2.1, 5.2.2, 5.2.3, 5.2.3.1, 5.3, 5.3.1, 5.3.2, 5.3.2.1, 5.3.3, 5.3.4, 5.3.5		
MDM-04	Mobile Device Management	Configuration Management: High Risk Travel Locations	Organization has a documented list of travel locations considered high risk for the use of mobile devices (i.e., laptops, smartphones, tablets). Employees procure alternate equipment before traveling to these locations.				X									X		X	X							8.1.10.3										CM-02 (07)		ISM-1298 ISM-1554 ISM-1555 ISM-1299 ISM-1088 ISM-1300 ISM-1556	6.2.1.1 6.2.2.2 6.2.2.3 6.2.2.9 6.2.2.10 6.2.2.11 6.2.2.12 6.2.2.13 6.2.2.14 6.2.2.15 6.2.2.16 6.2.2.17 6.2.2.19				

NO-01	Network Operations	Network Policy Enforcement Points	Network traffic to and from untrusted networks passes through a policy enforcement point; firewall rules are established in accordance with identified security requirements and business justifications.	X	X	X	X		X	X		X	X	X	X	X	X	X	X	X	X	X	X	PR.PT-4	CO5-01 CO5-03 CO5-04 CO5-05 CO5-06 CO5-08 OPS-24	4.4 4.5 12.5	8.1.2.1 8.1.3.1 8.1.3.2 8.1.10.6 8.2.2.1 8.2.3.1 8.3.2.3 8.2.2.1 (a)		Firewalls	4 8 9 10 24 25 73 74 75 76 77 94		8.2	CLD.13.1.4		CA-03 CM-07 SC-05 SC-07	CA-03 CM-07 SC-05 SC-07	CA-03 CM-07 SC-05 SC-07 SC-07 (04) SI-04 (04)	164.312(c)(1)	ISM-1416 ISM-1386 ISM-1528 ISM-0639	13.1.1 13.1.2 13.1.3 13.1.4 13.1.5 13.1.6 13.1.7 13.1.8 13.1.9 13.1.10 13.1.4.1.P 13.1.4.2.P 14.2.1 12.2.1.5	11.2	1.2	8.3.1	CC6.6
NO-02	Network Operations	Inbound and Outbound Network Traffic: DMZ Requirements	Network traffic to and from untrusted networks passes through a Demilitarized Zone (DMZ).		X		X		X			X						X	X		X	X			CO5-02 CO5-03 CO5-04 CO5-06 OPS-24		8.1.2.1 8.1.3.2 8.1.3.3		Firewalls			8.23						ISM-1181 ISM-1577 ISM-0637	13.1.3.1		1.4, 1.4.1	8.3.2	
NO-03	Network Operations	Ingress and Egress Points	Organization maintains an inventory of ingress and egress points on the production network and performs the following for each: - inventory is reduced to the minimum possible level - permitted ports, protocols and services are inventoried and validated - documents security features that are implemented for insecure protocols			X	X									X		X			X					4.5 4.6 12.1 12.2 12.6 13.9	8.1.4.4								CM-07 (01)		ISM-1502 ISM-1182 ISM-1427 ISM-1428 ISM-1427 ISM-0629			12.5, 12.6		
NO-04	Network Operations	Non-disclosure of Routing Information	Organization does not disclose private IP addresses and routing information to unauthorized parties.																		X																				1.4.3, 1.4.5		
NO-05	Network Operations	Dynamic Packet Filtering	Where applicable, Organization enables dynamic packet filtering on the network.			X	X							X	X	X		X			X					9.3 13.4 13.10	8.1.3.2							SC-05	SC-05	SC-05		ISM-1234 ISM-1289			1.3.1		
NO-06	Network Operations	Firewall Rule Set Review	Network infrastructure rule sets are reviewed every 6 months.						X									X			X								Firewalls										ISM-0521 ISM-1186 ISM-1428 ISM-1430			1.2.7		
NO-07	Network Operations	Ingress and Egress Points: Fail Secure	The information system fails securely in the event of an operational failure of a boundary protection device.				X										X				X						8.3.2.1									MA-06 SC-07 (18)				1.4.1		
NO-08	Network Operations	Traffic Flow: Managed Proxy	Organization requires egress traffic initiated from within the Organization network to pass through a managed proxy.			X											X		X		X					13.10									SC-07 (04) SC-07 (08)		ISM-0260 ISM-0963 ISM-0961 ISM-1237 ISM-1236 ISM-1171 ISM-0659 ISM-0651 ISM-0652 ISM-1524 ISM-1293 ISM-1389 ISM-0649 ISM-1284 ISM-1286 ISM-1287 ISM-0677			1.3.2		
NO-09	Network Operations	Domain Name Services Security Extensions (DNSSec)	Organization establishes a DNSSec implementation standard and uses mechanisms to verify the DNS infrastructure for compliance.			X									X			X								4.9 9.2									SC-21			ISM-1782					
NO-10	Network Operations	Email Spam Protection	Organization has documented procedures and protection mechanisms in place to protect its information and information systems from spam and ensures that signature definitions are updated whenever new releases are available.			X	X										X	X	X							9.1 9.5 9.6	8.1.3.4								SI-08 SI-08 (02)		ISM-0264 ISM-0267 ISM-0275 ISM-0272 ISM-1089 ISM-0565 ISM-1023 ISM-1024 ISM-1431 ISM-1458	13.2.1.2 13.2.3.6				
NO-11	Network Operations	Denial of Service (DOS)	Organization implements a Denial of Service (DOS) protection plan, identifies threatening DOS attacks, and configures boundary protection devices according to the DOS plan.				X											X									8.1.3.3 8.3.2.3											ISM-1519 ISM-1579 ISM-1431 ISM-1458 ISM-1435					
NO-12	Network Operations	Trusted Connections	All trusted connections are documented and approved by authorized personnel; management ensures the following documentation is in place prior to approval: - agreement with vendor - security requirements - nature of transmitted information			X	X							X	X	X		X			X					12.4	8.1.2.3 8.1.3.6 8.1.4.6							CA-03 SC-07 SC-21 SC-22	CA-03 SC-07 SC-21 SC-22	CA-03 SC-07 SC-21 SC-22		ISM-0516 ISM-0518 ISM-1178			1.3.1, 1.3.2		
NO-13	Network Operations	Network Segmentation	Production environments are logically segregated from non-production environments.	X	X	X	X			X		X			X	X	X	X	X	X	X	X	X	PR.DS-7 PR.AC-5	CO5-05 CO5-06 DEV-10 OPS-24	16.8	8.1.2.1 8.1.9.4			78 87 88 89 90		8.22 8.31			SC-39	SC-39	SC-39		ISM-0400 ISM-1419 ISM-1269 ISM-1270	9.5.1.2.P 9.5.1.3.P 12.1.4.1 12.1.4.2 12.1.4.3 12.1.4.4 12.1.4.5 12.1.4.6 12.1.4.7 13.1.3.1 13.1.3.2 13.1.3.3 13.1.3.4 13.1.3.5 13.1.3.6 13.1.3.7 13.1.3.10.P 13.1.3.11.P 14.2.1.1 14.2.6.7 12.2.1.14	5.7 5.8 11.2	6.5.3	8.3.2 8.3.3 10.1.4	CC6.1
NO-14	Network Operations	Card Processing Environment Segmentation	Where applicable, Organization segregates the Primary Account Number (PAN) infrastructure including payment card collection devices; Organization limits access to the segregated environment to authorized personnel.																		X																				6.5.3		
NO-15	Network Operations	Traffic Flow	Organization documents the approved traffic flow at each managed interface and configures the managed interface accordingly. Exceptions to traffic flow are documented, reviewed periodically, and removed when there is no longer a business requirement.			X	X					X					X		X		X					12.4	8.2.3.2					8.21					AC-04		ISM-0631 ISM-1192			1.3.1, 1.3.2		
NO-16	Network Operations	Disable Rogue Wireless Access Points	Organization employs mechanisms to detect and disable the use of unauthorized wireless access points.				X										X		X		X	X					8.1.2.3 8.1.4.6 8.3.2.3									AC-18 (01) SC-04		ISM-0345 ISM-1314 ISM-1315 ISM-1334 ISM-1338 ISM-1335			11.2, 11.2.1, 11.2.2	11.1.2	
NO-17	Network Operations	Wireless Access Points	Organization maintains an inventory of authorized wireless access points including a documented business justification.				X										X				X	X					8.3.2.1 8.3.2.3									AC-17 (03)				11.2, 11.2.1, 11.2.2	11.1.2	
NO-18	Network Operations	Authentication: Wireless Access Points	Organization restricts access to network services via wireless access points to authenticated users and services; approved wireless encryption protocols are required for wireless connections.			X	X							X	X	X		X	X		X					12.5 12.6	8.1.4.1 8.1.4.4 8.3.2.1 8.3.2.2							AC-18	AC-18	AC-18 AC-17 (01) AC-17 (03) AC-19 (05)		ISM-1532 ISM-0529 ISM-0530 ISM-0535 ISM-1364 ISM-0536 ISM-1317 ISM-1322 ISM-1454 ISM-0484 ISM-0485 ISM-1449 ISM-0487 ISM-0488 ISM-0489 ISM-0494 ISM-0496 ISM-1233	6.2.2.4 6.2.2.7 13.1.3.8 13.1.3.9		2.3, 2.3.1, 2.3.2, 4.2.1.2		
PR-01	People Resources	Background Checks	New hires are required to pass a background check as a condition of their employment.	X	X		X			X	X	X		X	X	X		X	X	X	X		X	PR.AC-6 PR.IP-11	HR-01		8.1.8.1		59 61 62	7.2	6.1			PS-03	PS-03	PS-03		ISM-0434	7.1.1.1 7.1.1.2 7.1.1.3 7.1.1.4 7.1.1.5 7.1.1.6 7.1.1.7 7.1.1.8 7.1.1.9 7.1.1.10 7.1.1.11 7.1.1.12 7.1.1.13 7.1.2.8 7.1.2.9	3.5	12.7, 12.7.1		CC1.4
PR-02	People Resources	Performance Management	Organization has established a check-in performance management process for on-going dialogue between managers and employees. Quarterly reminders are sent to managers to perform their regular check-in conversation.																				X																					CC1.4 CC1.5
PR-03	People Resources	Hiring Process	Job candidates apply for roles that are listed on the Organization career portal; candidates are interviewed to determine their knowledge and competence for their prospective roles and compatibility with Organization values.		X		X	X											X						HR-01		8.1.8.1 8.3.4.1	7.2(a) 7.2(b) 7.2(f) 7.2(d) 7.2												4.5.2.2 4.1.1.11 7.1.2.7 18.2.1.5				
PR-04	People Resources	Organization Property Collection	Upon employee termination, management is notified to collect Organization property from the terminated employee.		X		X			X		X			X	X	X		X						AM-05 HR-05		8.1.8.2		2 3 14 16 17 60		5.11			PS-04	PS-04	PS-04			6.2.2.21 8.1.3.2 8.1.4.1 8.1.4.2 8.1.4.4 8.1.5.2.P 8.1.5.3.P 9.2.2.1 9.2.6.1				
PR-05	People Resources	Exit Interviews	Upon employee termination, management conducts exit interviews for the terminated employee.		X									X	X	X									HR-05									PS-04	PS-04	PS-04							
PR-06	People Resources	Disciplinary Process	Employees that fail to comply with Organization policies are subject to a disciplinary process.		X			X		X	X	X		X	X	X	X		X				X		HR-04			7.3.0	60	7.3(c)	6.4			PS-08	PS-08	PS-08	164.308(a)(1)(ii)(C)		4.5.2.8 7.2.6 7.2.3.1 7.2.3.2 7.2.3.3 7.2.3.4					CC1.5
PR-07	People Resources	Code of Ethics	Organization has a Code of Ethics for Senior Officers. The Senior Officers and CEO certify that they understand the Code on an annual basis.											X	X	X																		PL-04	PL-04	PL-04							
PR-08	People Resources	Business Ethics Hotline	Organization has a business ethics hotline for employees and external parties to report ethical misconduct. Allegations are investigated and Organization will take appropriate action for confirmed violations. Hotline reports are reported to the Audit Committee on a quarterly basis.											X	X	X			X				X											PS-08	PS-08	PS-08			7.2.1.7 18.1.2.13.PB					CC2.2
PR-09	People Resources	National Security Clearance	Organization conducts screening and rescreening of authorized personnel for roles that require national security clearances. For national security clearances; a reinvestigation is required during the 5th year for top secret security clearance, the 10th year for secret security clearance, and 15th year for confidential security clearance. In addition, for law enforcement and high impact public trust level, a reinvestigation is required during the 5th year.											X	X	X																			PS-03	PS-03	PS-03							
PR-10	People Resources	Code of Business Conduct	Organization has documented the Code of Business Conduct and Business Partner Code of Conduct, which are reviewed, updated if applicable, and approved by senior management annually.											X	X	X							X											PL-04	PL-04	PL-04								CC1.1
PRIV-01	Privacy	Privacy Program	Organization privacy policies for individuals, including relevant updates, are communicated on the public company website or on the internal corporate network.										X					X															A.7.1						18.1.4.1 18.1.4.2 18.1.4.3 18.1.4.4					
PRIV-02	Privacy	Privacy Program Review	On an annual basis, Organization performs a review of privacy practices to ensure the following: - consent is obtained for users whose personal information (PI) is managed by Organization - PI inventory integrity and accuracy - data access request response template is understandable - standard agreement templates are up-to-date - requests to delete, access or update PI are processed accurately and within a timeframe consistent with Organization policy - compliance with Organization's privacy commitments - known privacy issues are remediated - opt-in and opt-out compliance with applicable law - Organization privacy documentation and practices are relevant to applicable law - compliance with relevant industry Codes of Conduct (e.g., EDAA) - if applicable, joint controller responsibilities are clearly defined and communicated to both data controllers and the data subject									X		X			X															5.34		A.11.1					ISM-1451					
PRIV-03	Privacy	Privacy Readiness Review	Organization performs privacy readiness reviews to identify high-risk processing activities that impact personal data; identified non-compliance with Organization privacy practices is tracked through remediation.							X																				91														
PRIV-04	Privacy	Privacy Notice	Individuals are given appropriate notice and an opportunity to consent or decline to Organization privacy practices such as accessing, collecting, processing, transferring, or storing personal information.		X								X					X							IDM-07								A.2.1 A.2.2 A.7.1					ISM-0347 ISM-0663 ISM-0665					

PRIV-05	Privacy	Personal Information Notice and Consent: Additional Processing Activities	Where appropriate, Organization obtains individual consent for processing activities for which consent has not been previously obtained.		X		X						X												IDM-07		8.1.4.11							A.2.2											
PRIV-06	Privacy	Notice of Personal Information Disclosure	In accordance with Organization policy, Organization provides notice to individuals regarding legally-required disclosures of personal information.				X						X										X			8.2.4.5 (a)							A.5.1											C1.1
PRIV-07	Privacy	PII Processing Agreements	Personal information is handled and processed in accordance with contractual requirements.		X							X		X					X						PS5-12 INQ-2 INQ-3 INQ-4							5.34		A.2.1						18.1.5.6					
PRIV-08	Privacy	Record of Processing Activity	Organization documents, reviews, and approves a record of processing activities related to personal information.									X							X														5.34								18.1.4.6					
PRIV-09	Privacy	Document Management Standard: HIPAA	Documentation that impacts personal health information, including policies, procedures, and the documentation of actions, activities, or assessments, are retained for 6 years from the date of its creation, or the date when it last was in effect, whichever is later.															X																				164.316(b)(2)(i)							
PRIV-10	Privacy	Law Enforcement Requests	Law enforcement agencies may submit requests for evidence; submitted requests are reviewed and tracked to resolution.		X							X													INQ-01							5.34													
PS-01	Proactive Security	Endpoint Detection and Response	Endpoint Detection and Response (EDR) software is deployed to continuously monitor, detect, and respond to cyber threats and patterns of malicious behavior and activity.			X																				13.2 13.7																			
PS-02	Proactive Security	Threat Hunting	Organization performs threat hunting to identify, track, and disrupt threats that evade existing security controls.									X																				5.7													
PS-03	Proactive Security	Threat Modeling	Organization performs periodic threat modeling to ensure that potential threats are identified and assessed.			X																				16.14																			
PS-04	Proactive Security	Adversary Intelligence	Organization gathers intelligence on adversary personas to assist in the prioritization of security activities.									X																				5.7													
RM-01	Risk Management	Service Risk Rating Assignment	Annually, Organization prioritizes the frequency of vulnerability discovery activities based on an assigned service risk rating.							X	X				X	X	X		X			X							1 6 7 47 48 49	4.1 8.1 8.2 8.3 10.2 6.1.1 6.1.2 6.1.3 6.2(c) 9.1				CA-07	CA-07	CA-07 RA-05 (02) RA-05 (03)		ISM-1608 ISM-1688 ISM-1698 ISM-1699 ISM-1700 ISM-1701 ISM-1702 ISM-1752 ISM-1703 ISM-1656 ISM-1755			12.3, 12.3.1, 12.3.2, 12.3.3, 12.3.4		
RM-02	Risk Management	Risk Assessment	Organization management performs an annual risk assessment. Results from risk assessment activities are reviewed to prioritize mitigation of identified risks.	X	X			X		X	X				X	X	X		X	X	X	X		X	ID.GV-4 ID.RA-6 ID.RM-1 ID.RM-2 ID.RM-3	COM-03 DEV-01 OIS-04 OIS-06 OIS-07 OPS-20 SSO-05			6.1.1(a) 6.1.1(b) 6.1.1(c) 6.1.2(b,2) 8.2.3(a) 8.2.3(b) 8.2.3(c) 8.3.1 8.3.2(a) 8.3.2(b) 8.3.2(c) 8.3.2(d)		1 5 6 7 47 48 49	4.1 8.1 8.2 8.3 10.2 6.1.1 6.1.2 6.1.3 6.1.3(a) 6.1.3(b) 6.1.3(e) 6.1.3(f) 6.2(c) 9.1				CA-07 (04)	RA-03 CA-07 (04)	RA-03 SA-09 (02)		ISM-0726 ISM-1587 ISM-1620 ISM-1567 ISM-1563 ISM-1588	3.1.2.2 3.1.3.1 3.1.4.3 4.4.6.1 4.4.7.1 4.4.7.2 4.4.7.3 4.4.7.4 4.4.8.1 4.4.8.4 4.4.8.5 4.5.4.1 4.5.5.1 4.6.1.1 4.8.1.1 4.9.2.1 4.9.2.2 6.1.1.3 14.1.1.1 14.2.6.3 14.2.6.4 14.2.6.5 14.2.6.9 14.2.6.10	3.1 4.1 4.2 4.3		12.3, 12.3.1, 12.3.2, 12.3.3, 12.3.4		CC3.2 CC3.3 CC3.4 CC9.1
RM-03	Risk Management	Risk Assessment: HIPAA Criteria	Organization's periodic risk assessment for systems that process, transmit or store Protected Health Information (PHI) includes the following: - identify and classify assets - identify threats - identify vulnerabilities - identify controls - perform threat likelihood analysis - perform threat impact analysis - identify residual risk - identify appropriate safeguards															X																					164.308(a)(1)(ii)(A) 164.308(a)(1)(ii)(B) 164.308(a)(8)											
RM-04	Risk Management	Continuous Monitoring	The design and operating effectiveness of internal controls are continuously evaluated against the established Common Controls Framework by Organization. Corrective actions related to identified deficiencies are tracked to resolution.		X		X	X		X	X	X			X	X	X	X	X	X	X	X	X		COM-02 COM-03		8.1.10.6	8.1(a) 8.1(b)		2 3 5 47 48 49	9.1 9.3 10.1	5.29			CA-05 CA-07	CA-05 CA-07	CA-05 CA-07	164.308(a)(8)	ISM-1700 ISM-1701 ISM-1702 ISM-1752 ISM-1703	3.1.4.2 4.4.8.2 4.4.8.3 4.5.4.1 4.5.5.3 4.6.2.3 4.6.2.4 4.6.3.1 4.7.1.2 4.7.1.3 4.7.1.4 4.7.1.6 12.7.1.1 12.7.1.5 12.7.1.6 18.2.1.2 18.2.1.3 18.2.1.4 18.2.2.1 18.2.2.2 18.2.3.1 18.2.3.2	3.2 4.1 15.1	12.3, 12.3.1, 12.3.2, 12.3.3, 12.3.4, A3.3.3	2.2.1	CC2.1 CC4.1 CC4.2
RM-05	Risk Management	Self-Assessments: PCI	On a quarterly basis, reviews shall be performed with approved documented specification to confirm personnel are following security policies and operational procedures pertaining to: - daily log reviews - firewall rule-set reviews - applying configuration standards to new systems - responding to security alerts - change management processes															X				X																			ISM-1294				12.4.2, 12.4.2.1		
RM-06	Risk Management	Internal Audits	Organization establishes internal audit requirements based on the Common Controls Framework by Organization and executes audits on information systems and processes at planned intervals.		X			X		X	X	X			X	X	X			X					COM-03			8.6(d) 9.2.1(a.1) 9.2.2(a.2) 9.2.3(b) 9.2.2(a) 9.2.2.(b) 9.2.2.(c) 9.2.2.(d) 9.2.2.(e) 9.2.2.(g)		2 3 5	9.2	5.36 8.34			ALI-01 CA-05 CA-07	ALI-01 CA-05 CA-07	ALI-01 CA-05 CA-07			4.6.2.2 4.6.2.7					
RM-07	Risk Management	ISMS Internal Audit Requirements	Internal audit establishes and executes a plan to evaluate applicable controls in the Information Security Management System (ISMS) at least once every 3 years.								X				X	X	X		X												9.2				CA-02	CA-02	CA-02			4.7.1.5					
RM-08	Risk Management	Remediation Tracking	Management prepares a remediation plan to formally manage the resolution of findings identified in risk assessment activities.			X		X		X	X				X	X	X		X		X					16.3		6.1.2(a) 6.1.2(b.1) 9.2.2(f) 10.1.1 10.1.2(a.1) 10.1.2(a.2) 10.1.2(b.1) 10.1.2(b.2) 10.1.2(b.3) 10.1.2(c) 10.1.2(d) 10.1.2(- 10.1.2		5 6 7	6.1.3(e) 6.1.3(f) 8.3 10.1 10.2				RA-03 RA-07	RA-03 RA-07	RA-03			4.5.5.2 4.7.1.1 12.7.1.8		12.3, 12.3.1, 12.3.2, 12.3.3, 12.3.4		
RM-09	Risk Management	ISMS Corrective Action Plans	Management prepares a Corrective Action Plan (CAP) to manage the resolution of nonconformities identified in independent audits.								X				X	X	X	X	X											6.1.3(e) 6.1.3(f) 10.1 10.2				RA-03	RA-03	RA-03		ISM-1564	3.1.5.2					
RM-10	Risk Management	Statement of Applicability	Management prepares a statement of applicability that includes control objectives, implemented controls, and business justification for excluded controls. Management aligns the statement of applicability with the results of the annual risk assessment.							X	X									X									2 3 5	6.1.3(b) 6.1.3(c) 6.1.3(d)												12.3, 12.3.1, 12.3.2, 12.3.3, 12.3.4		
SDO-01	System Design Documentation	System Documentation	Documentation of system boundaries and key aspects of their functionality are published to authorized Organization personnel on the Organization intranet.		X	X	X								X	X				X	X		X		COS-07 COS-08 PI-01	3.8	8.1.9.5								CA-03 CA-09 SA-05	CA-03 CA-09 SA-05	CA-03 CA-09 SA-05				5.6	12.5.1, 12.5.2, 12.5.2.1, 12.5.3		CC2.2
SDO-02	System Design Documentation	Whitepapers	Organization publishes whitepapers to its public website that describe the purpose, design and boundaries of the system and system components.		X		X												X			X			COS-02 COS-07 COS-08 OIS-03 PI-01 PS5-01		8.2.2.1 8.2.4.5 8.2.4.6 8.2.5.1															4.5.3.1 6.1.3.3.PB 6.3.1.1.PB 8.2.2.7.PB 10.1.1.9.PB 10.1.1.10.P 13.1.1.1.P 13.1.3.1.P 14.1.1.9.P 14.2.1.1.PB 16.1.7.P 16.1.1.8.P 16.1.1.9.P 16.1.1.10.P 16.1.1.1.P 16.1.1.12.P 16.1.1.5.P 18.1.4.P 18.1.6.P 18.1.7.P 18.1.3.1.1.PB 18.1.5.2.PB 18.2.1.9.P 10.1.2.2.(PB					CC2.3
SG-01	Security Governance	Policy and Standard Review	Organization's policies and standards are periodically reviewed, approved by management, and communicated to Organization personnel.	X	X	X	X	X		X	X	X		X	X	X	X	X	X	X	X	X	X	ID.GV-1 ID.AM-6	AM-02 COM-01 COM-02 COM-03 COS-08 CRY-01 DEV-01 DEV-03 IDM-01 OIS-02 OIS-06 OPS-04 OPS-06 OPS-10 OPS-11 OPS-12 OPS-18 SP-01 SP-02	7.1 11.1 12.4 18.1	8.1.5.4 8.2.5.1	4.1 5.2.1(a) 5.2.1(b) 5.2.1.(c) 5.2.1(d) 5.2.2(a) 5.2.2(b) 5.2.2(c) 7.3(a)		1 2 3 4 27 28 88 89 90	5.1(a) 5.1(d) 5.2(d) 5.2(e) 5.2(g) 7.3(a) 7.3(b) 7.3(c) 7.5.1(b) 7.5.2(a) 7.5.2(b) 7.5.2(c) 7.5.3(a) 7.5.3(b) 7.5.3(c) 7.5.3(d) 7.5.3(e) 7.5.3(f)	5.1		A.9.2 A.10.12	PL-01 PS-06	PL-01 PS-06	PL-01 PS-06	164.308(a)(2)(i) 164.306(a)(3)(i) 164.308(a)(4)(i) 164.308(a)(4)(ii)(B) 164.308(a)(4)(ii)(c) 164.308(a)(7)(i) 164.308(a)(7)(ii)(D) 164.308(a)(8) 164.310(a)(1) 164.312(c)(1) 164.314(b)(1)(i) 164.314(b)(1)(ii) 164.314(b)(2)(iii) 164.314(b)(2)(iv)	ISM-0888 ISM-1602	3.1.4.2 4.4.1.1 4.4.5.1 4.4.5.3 4.5.2.4 4.5.2.7 4.8.1.1 4.8.2.1 4.8.2.2 5.1.1.1 5.1.1.2 5.1.1.3 5.1.1.4 5.1.1.5 5.1.1.6 5.1.1.8 5.1.1.9 5.1.1.10 5.1.1.11 5.1.1.12 5.1.1.13 5.1.1.14 5.1.1.15 5.1.1.16	3.1 3.2 4.4 5.1 5.4 7.1	1.1, 1.1.1, 2.1, 2.1.1, 3.1, 3.1.1, 4.1, 4.1.1, 5.1, 5.1.1, 6.1, 6.1.1, 7.1, 7.1.1, 8.1, 8.1.1, 9.1, 9.1.1, 10.1, 10.1.1, 11.1, 11.1.1, 12.1, 12.1.1, A3.1.3	1.1.1 1.1.2	CC2.2 CC5.3
SG-02	Security Governance	Exception Management	Organization reviews exceptions to policies, standards and procedures; exceptions are documented and approved based on business need and removed when no longer required.		X	X	X			X									X	X		X			SP-03	2.2	8.1.5.1			1 2 3											5.1.1.1 5.1.1.7	3.2			CC3.2 CC5.3
SG-03	Security Governance	Document Control	Organization's document management criteria is periodically reviewed, approved by management, and communicated to authorized personnel; management determines the treatment and retention of documentation according to legal and regulatory requirements.		X		X	X						X				X	X		X			SP-01		8.1.5.4	4.2.2 © 7.5.2(a) 7.5.2(b) 7.5.2© 7.5.3.1(a) 7.5.3.1(b) 7.5.3.2(a) 7.5.3.2(b) 7.5.3.2© 7.5.3.2(d)							A.9.2				ISM-0047	5.1.2.2		1.1, 1.1.1, 2.1, 2.1.1, 3.1, 3.1.1, 4.1, 4.1.1, 5.1, 5.1.1, 6.1, 6.1.1, 7.1, 7.1.1, 8.1, 8.1.1, 9.1, 9.1.1, 10.1, 10.1.1, 11.1, 11.1.1, 12.1, 12.1.1		

SG-04	Security Governance	Information Security Program Content	The Chief Security Officer conducts a periodic staff meeting to communicate and align on relevant security threats, program performance, and resource prioritization.	X	X					X	X	X			X	X	X	X	X	X		X		X	ID.AM-3 PR.IP-8	COM-01 OIS-05 SP-01				1 2 3 4 5 15 24 25 60 68 69 73	5.1 5.1(e) 5.1(f) 5.1(g) 5.1(h) 6.2(b) 7.5.2 7.5.2(a) 7.5.2(b) 8.1 6.3	5.35 8.26			AT-01 CA-06 IA-01 PL-02	AT-01 CA-06 IA-01 PL-02 SA-02	AT-01 CA-06 IA-01 PL-02 SA-02	164.308(a)(5)(i)(A)	ISM-0432	3.1.3.3 4.4.1.1 4.6.1.2 4.8.2.1 11.2.9.6		12.4.2, 12.4.2.1		CC1.3 CC3.1
SG-05	Security Governance	Procedures	Organization's key control capabilities are supported by documented procedures that are communicated to authorized personnel.									X			X	X	X			X		X										5.37			AC-01 AT-01 AU-01 CA-01 CM-01 IA-01 IR-01 IR-08 MA-01 MP-01 PE-01 PL-01 PL-02 PS-01 RA-01 SA-01 SC-01 SI-01	AC-01 AT-01 AU-01 CA-01 CM-01 IA-01 IR-01 IR-08 MA-01 MP-01 PE-01 PL-01 PL-02 PS-01 RA-01 SA-01 SC-01 SI-01	AC-01 AT-01 AU-01 CA-01 CM-01 IA-01 IR-01 IR-08 MA-01 MP-01 PE-01 PL-01 PL-02 PS-01 RA-01 SA-01 SC-01 SI-01			8.1.4.3 12.1.1.1 12.1.1.2 12.1.1.4 12.1.1.5 12.1.1.6 12.1.1.7 12.1.1.8 12.1.1.9 12.1.1.10 12.1.1.11 12.1.1.12 12.1.1.13		11, 11.1, 11.2, 11.3, 11.3.1, 11.3.2, 11.3.3, 11.3.4, 11.4, 11.4.1, 11.4.2, 11.4.3, 11.4.4, 11.4.5, 11.4.6, 11.4.7, 11.4.8, 11.4.9, 11.5, 11.5.1, 11.5.2, 11.5.3, 11.5.4, 11.5.5, 11.5.6, 11.5.7, 11.5.8, 11.5.9, 11.5.10, 11.5.11, 11.5.12, 11.5.13, 11.5.14, 11.5.15, 11.5.16, 11.5.17, 11.5.18, 11.5.19, 11.5.20, 11.5.21, 11.5.22, 11.5.23, 11.5.24, 11.5.25, 11.5.26, 11.5.27, 11.5.28, 11.5.29, 11.5.30, 11.5.31, 11.5.32, 11.5.33, 11.5.34, 11.5.35, 11.5.36, 11.5.37, 11.5.38, 11.5.39, 11.5.40, 11.5.41, 11.5.42, 11.5.43, 11.5.44, 11.5.45, 11.5.46, 11.5.47, 11.5.48, 11.5.49, 11.5.50, 11.5.51, 11.5.52, 11.5.53, 11.5.54, 11.5.55, 11.5.56, 11.5.57, 11.5.58, 11.5.59, 11.5.60, 11.5.61, 11.5.62, 11.5.63, 11.5.64, 11.5.65, 11.5.66, 11.5.67, 11.5.68, 11.5.69, 11.5.70, 11.5.71, 12.1, 12.1.1		
SG-06	Security Governance	Proprietary Rights Agreement	Organization regular employees consent to a proprietary rights agreement.		X					X		X		X					X							HR-06 IDM-08				40 60		5.32 6.2		A.10.1					7.1.2.3 18.1.2.3 7.1.2.4 7.1.2.5				
SG-07	Security Governance	Review of Confidentiality Agreements	The Organization Proprietary Rights Agreement and Organization Network Access Agreement are reviewed on a periodic basis.		X					X					X	X	X		X							HR-06				40 60					PS-06	PS-06	PS-06			18.1.2.11				
SG-08	Security Governance	Information Security Program	Organization has an established security leadership team including key stakeholders in the Organization Information Security Program; goals and milestones for deployment of the information security program are established and communicated to the company through the periodic security all-hands meeting.	X	X	X				X	X	X			X	X	X	X	X	X	X	X	X	X	ID.BE-2 ID.BE-3	BCM-01 COM-01 OIS-01 OIS-02 OIS-06 SP-01		8.1.6.1 8.1.7.1 8.1.7.2 8.1.9.2		1	4.2 5.1 5.1(a) 5.1(e) 5.1(f) 5.1(g) 5.1(h) 5.2(d) 5.2(f) 6.2(a) 6.2(d) 6.2(e) 6.2(f) 6.2(i) 6.2(j) 7.2 7.5.1(a) 9.3 6.3	5.4			CA-06 PL-02	CA-06 PL-02	CA-06 PL-02	164.308(a)(2)	ISM-0754 ISM-1478 ISM-1477 ISM-0725 ISM-0798 ISM-0733 ISM-1698 ISM-0734 ISM-0720	3.1.2.1 3.1.2.3 3.1.3.4 3.1.5.4 3.1.5.5 4.4.1.1 4.4.1.3 4.4.3.1 4.5.2.1 4.5.2.7 4.5.3.1 4.5.4.2 4.6.1.2 4.6.3.1 5.1.1.1 6.1.4.7 6.1.5.1 12.1.2.13 12.1.2.14 12.2.1.12 14.1.1.3 14.1.1.4 18.2.2.8	3.1	12.1.4	12.1	CC1.3
SG-09	Security Governance	Accessibility Program	Organization has an established accessibility leadership team including key stakeholders, goals and milestones for deployment of the accessibility program are established and communicated to the company.												X	X	X																		CA-06	CA-06	CA-06							
SG-10	Security Governance	Information Security Management System Scope	Information Security Management System (ISMS) boundaries are formally defined in an ISMS scoping document.				X			X	X				X	X	X			X								8.1.6.2		1 4 5 6 7 47 48 49 60	4.2 4.3 4.4 5.2 6.2 7.4 7.5.1 8.1 9.1 9.3				PL-02	PL-02	PL-02			4.4.4.1 4.4.5.2				
SG-11	Security Governance	Security Roles and Responsibilities	Roles and responsibilities for the governance of Information Security within Organization are formally documented within the Information Security Management Standard and communicated on the Organization intranet.	X	X	X	X			X	X	X			X	X	X	X	X	X	X	X			ID.AM-6 ID.BE-2 ID.BE-3 ID.GV-2 PR.AT-2 PR.AT-3 PR.AT-4 PR.AT-5 DE.DP-1	BCM-01 COM-01 OIS-01 OIS-02 OIS-06	17.5	8.1.5.3 8.1.6.2 8.1.6.3 8.1.7.3 8.1.9.1 8.1.9.2 8.1.10.6			1 4 5 60 61 62	5.1(f) 5.1(g) 5.1(h) 5.3 6.2(h) 7.2	6.5			CA-06 PL-04	CA-06 PL-04 PS-09	CA-06 PL-04	164.308(a)(2) 164.308(a)(3)(i)	ISM-1071 ISM-1634 ISM-1635	3.1.5.3 4.4.1.2 4.4.3.1 4.5.2.7 4.1.1.1 6.1.1.4 6.1.1.6 6.1.1.7 6.1.1.8 6.1.1.9 6.1.1.10 6.1.1.11 6.1.5.6	3.1 4.1	12.1.3	12.2 2.1.1	CC1.3
SG-12	Security Governance	Security Roles and Responsibilities: Risk Designations	Organization defined security roles and responsibilities are assigned risk designations and reviewed at least once every three years.			X	X								X	X	X	X			X						17.5	8.1.6.3							PS-02	PS-02	PS-02		ISM-1525 ISM-1633 ISM-1634 ISM-1635			12.1.3		
SG-13	Security Governance	Security Roles and Responsibilities: PCI Compliance	Roles and responsibilities and a program charter for the governance of PCI DSS compliance within Organization are formally documented and communicated by management.																		X																			12.4.1, A3.1.1, A3.1.2, A3.2, A3.2.1, A3.2.2, A3.3		
SG-14	Security Governance	Information Security Resources	Information systems security implementation and management are included as part of the budget required to support the Organization Security Program.				X				X						X	X		X	X							8.1.9.6			5.1(c) 7.1				SA-02	SA-02		ISM-0732 ISM-0120	3.1.6.2 4.5.1.1 4.5.1.2 4.5.5.3				
SG-15	Security Governance	Management Review	The Information Security Management System (ISMS) steering committee conducts a formal management review of ISMS scope, risk assessment activities, control implementation, and audit results on an annual basis.		X		X	X			X					X	X	X		X	X					COM-04		8.1.6.2 8.1.6.4 8.1.10.6	9.3.1 9.3.2(a) 9.3.2(b) 9.3.2(c.1) 9.3.2(c.2) 9.3.2(c.3) 9.3.2(d) 9.3.2(e) 9.3.2(f) 9.3.2(g) 9.3.2(h) 9.3.2(i)			9.3				CA-06	CA-06	CA-06		ISM-1636 ISM-0027 ISM-1587	4.6.3.2 4.6.3.3 4.6.3.4 4.7.1.7				
SG-16	Security Governance	Enterprise Data Catalog	Organization maintains an enterprise data catalog that encompasses key organizational data, environment metadata, and product information to facilitate continuous monitoring of the internal control environment. The enterprise data catalog is updated as part of the continuous monitoring process and upon the introduction of new service offerings and acquisitions.			X													X								3.2												ISM-1572					
SG-17	Security Governance	Software Usage Restrictions	Organization maintains software license contracts and monitors its compliance with usage restrictions.			X	X		X						X	X	X			X	X						2.1 2.2 2.3 2.4 2.5 2.6	8.1.4.4		Security Update Management					CM-10	CM-10	CM-10 AU-09 (04)			9.4.4.2 9.4.4.10.P 12.2.1.7 18.1.2.1 18.1.2.5 18.1.2.6 18.1.2.7 18.1.2.8 18.1.2.9 18.1.2.10 12.2.1.2 18.1.2.2 12.6.2.1		12.2, 12.2.1		
SLC-01	Service Lifecycle	Service Lifecycle Workflow	Major software releases are subject to the Service Life Cycle, which requires acceptance via Concept Accept and Project Plan Commit phases prior to implementation.	X	X	X				X		X			X	X	X	X	X	X	X	X	PR.IP-2	DEV-01	16.1 16.2 16.10				8 9 10 11 12 87		8.2.5 8.2.7 5.8 8.2.8			SA-03 SA-04	SA-03 SA-04 SA-08 PL-08	SA-03 SA-04 SA-04 (01) PL-08		ISM-1759 ISM-0041 ISM-1460 ISM-1604 ISM-0401 ISM-1780 ISM-1239 ISM-1241 ISM-1424 ISM-1278	6.1.5.2 6.1.5.3 6.1.5.4 6.1.5.5 12.5.1.14 14.1.1.7 14.1.1.12 14.1.1.14 14.1.1.15 14.1.1.16 14.1.1.17 14.1.1.18 14.2.1.2 14.2.1.4 14.2.1.7 14.2.3.1 14.2.5.2 14.2.5.3 14.2.5.4 14.2.5.5 14.2.5.6 14.2.5.8 14.2.6.8 14.2.8.2	5.1 5.2 5.4 5.7	6.1, 6.2, 6.2.1, 6.2.2, 6.2.3, 6.2.3.1		CC8.1
SLC-02	Service Lifecycle	Source Code Management	Source code is managed with Organization-approved version control mechanisms.		X	X	X			X								X	X	X		X		DEV-08	2.7 4.6 12.3	8.1.6.3 8.1.9.4 8.1.9.5 -ID			87									9.4.5.2 9.4.5.3 9.4.5.4 9.4.5.5 9.4.5.6 9.4.5.7 9.4.5.8 9.4.5.9 12.5.1.2 14.2.1.5 14.2.1.6 14.2.2.14	5.7 6.3 7.6	6.1, 6.2, 6.2.1, 6.2.2, 6.2.3, 6.2.3.1		CC6.8 CC8.1
SLC-03	Service Lifecycle	Secrets in Code	Organization manages source code secrets in a centralized repository; secrets are rotated at least annually and immediately if the security of secrets is compromised.				X												X		X							8.1.5.4											ISM-1559			8.6, 8.6.1, 8.6.2, 8.6.3		
SLC-04	Service Lifecycle	Project Budget Approval	Approval for project initiation and budget is obtained from IT management and business owners.																																										
SLC-05	Service Lifecycle	Project Scope Change	Changes to finalized project scope and requirements require the review and approval from the business team and project manager.				X																					8.1.9.6																
SLC-06	Service Lifecycle	Information System Operation Authorization	Senior management authorizes the operation of new information systems, based on security and business requirements, prior to implementation. The information system authorization is refreshed every 3 years or when significant change occurs.														X	X	X																		MA-06		ISM-1759 ISM-0041	14.2.5.9				
SLC-07	Service Lifecycle	System Acquisition Approval	Information system acquisitions require approval from authorized personnel based on verification of the following documented evidence: - security function, strength, and assurance requirements - requirements for protecting security-related documentation - system development and test requirements - acceptance criteria for releases - enumeration of Security controls - security control implementation and monitoring requirements - components are FIPS-201 approved			X	X										X	X									16.11	8.1.9.6 8.1.9.7							SA-04 SA-22	SA-04 SA-04 (10)	SA-04 SA-04 (02)							

SM-01	Systems Monitoring	Audit Logging	Organization logs critical information system activity.	X	X	X	X			X		X			X	X	X	X	X	X	X	X	X	X	DE.AE-3	AM-01 DEV-07 IDM-06 OIS-04 OPS-10 OPS-11 OPS-12 OPS-15 OPS-17 PSS-04	1.4 3.14 8.1 8.2 8.5 8.12 13.6	8.15.2 8.2.3.3			33 34 35 46		8.15 5.33			AU-02 AU-12	AU-02 AU-12	AU-02 AU-12 AU-07 (01)	164.312(b) 164.312(c)(2)	ISM-1714 ISM-1613 ISM-1660 ISM-1664 ISM-0582 ISM-1677 ISM-1607 ISM-0580 ISM-1405 ISM-1137 ISM-0634 ISM-0281 ISM-1778 ISM-1586	9.4.4.6 12.4.11 12.4.12 12.4.13 12.4.14 12.4.15 12.4.16 12.4.17 12.4.18 12.4.19 12.4.110 12.4.111 12.4.112 12.4.113 12.4.114 12.4.117 12.4.118 12.4.31 12.4.3.2 12.4.3.3 12.5.1.9 12.7.17 14.1.1.9	9.2 12.2	10.2, 10.2.1, 10.2.11, 10.2.12, 10.2.13, 10.2.14, 10.2.15, 10.2.16, 10.2.17, 10.2.2, A.12, A12.1	1.4.1	CC7.1
SM-02	Systems Monitoring	Secure Audit Logging	Organization logs critical information system activity to a secure repository. Organization disables administrators ability to delete or modify enterprise audit logs; the number of administrators with access to audit logs is limited.		X	X							X				X		X					OPS-16	8.2 8.5 8.6 8.7 8.8 8.9 8.12 12.5												AU-06 (03) AU-07		ISM-1573 ISM-1714 ISM-1715 ISM-1663 ISM-1665 ISM-1747 ISM-1678 ISM-1683 ISM-1684 ISM-1705 ISM-1706 ISM-1707 ISM-1708 ISM-0859 ISM-0995 ISM-1536 ISM-1757 ISM-1758 ISM-1775 ISM-1776 ISM-1777			10.3, 10.3.1, 10.3.2, 10.3.3, 10.3.4		
SM-03	Systems Monitoring	Audit Logging: Cardholder Data Environment Activity	Organization logs the following activity for cardholder data environments: - individual user access to cardholder data - administrative actions - access to logging servers - failed logins - modifications to authentication mechanisms and user privileges - initialization, stopping, or pausing of the audit logs - creation and deletion of system-level objects - security events - logs of all system components that store, process, transmit, or could impact the security of cardholder data (CHD) and/or sensitive authentication data (SAD) - logs of all critical system components - logs of all servers and system components that perform security functions (e.g., firewalls, intrusion-detection systems/intrusion-prevention systems (IDS/IPS), authentication servers, e-commerce redirection servers, etc.)														X		X																					ISM-1034			10.2, 10.2.1, 10.2.11, 10.2.12, 10.2.13, 10.2.14, 10.2.15, 10.2.16, 10.2.17, 10.2.2		
SM-04	Systems Monitoring	Audit Logging: Cardholder Data Environment Event Information	Organization records the following information for confirmed events in the cardholder data environment: - user identification - type of event - date and time - event success or failure indication - origination of the event - identification of affected data, system component, or resource			X													X							8.1																		10.2.2		
SM-05	Systems Monitoring	Audit Logging: Service Provider Logging Requirements	Organization establishes unique logging and audit trails for each entity's cardholder data environment and complies with the following: - logs are enabled for third-party applications - logs are active by default - logs are available for review by and communicated to the owning entity																X																								10.3, 10.3.1, 10.3.2, 10.3.3, 10.3.4		
SM-06	Systems Monitoring	Configuration Management: Remote Logging	Where applicable, devices are configured to send audit log data to a remote server				X												X								8.1.10.6 8.2.3.3																5.3.4		
SM-07	Systems Monitoring	Chain of Accountability	Organization implements audit trails to link authentication events to individuals users in production systems.				X												X								8.1.3.5																10.3, 10.3.1, 10.3.2, 10.3.3, 10.3.4		
SM-08	Systems Monitoring	Audit Record Time Stamps	Organization records time stamps for audit records that can be mapped to a centralized time source				X									X	X	X		X							8.1.3.5 8.1.4.3								AU-08	AU-08	AU-08		ISM-0585 ISM-0988			10.2.2		
SM-09	Systems Monitoring	Log Reconciliation: CMDB	Organization reconciles the established device inventory against the enterprise big repository on a quarterly basis; devices which do not forward log data are remediated.			X													X							8.9																	12.4.2.3		10.4, 10.4.1, 10.4.11, 10.4.2, 10.4.21, 10.4.3		
SM-10	Systems Monitoring	Audit Log Capacity and Retention	Organization allocates audit record storage capacity in accordance with logging storage and retention requirements; Audit logs are retained for 1 year with 90 days of data immediately available for analysis.		X	X	X			X					X		X	X	X	X				OPS-14	8.1 8.3 8.9 8.10	8.15.2				46					AU-04 AU-11 CA-07	AU-04 AU-11 CA-07	AU-04 AU-11 CA-07 AU-06 (03)				12.4.2.3		10.5, 10.5.1,	1.4.1	
SM-11	Systems Monitoring	Enterprise Antivirus Logging	If applicable, Organization's managed enterprise antivirus deployments generate audit logs which are retained for 1 year with 90 days of data immediately available for analysis.			X				X							X		X							8.10					46									ISM-1672			10.5, 10.5.1		
SM-12	Systems Monitoring	Security Monitoring Alert Criteria	Organization defines security monitoring alert criteria, how alert criteria will be flagged, and identifies authorized personnel for flagged system alerts.	X	X	X	X	X		X					X	X	X	X		X	X	X	X	DE.AE-5 DE.CM-2	COS-01 IDM-06 OPS-10 OPS-13 PSS-04	13.1 13.11	8.15.4 8.1.9.2	9.1(a)			15 33 34 35 46				AU-02 AU-03 AU-06 AU-12 AC-02 (12) AU-06 (09) CA-07 (09) SI-04 (02) SI-04 (05)	AU-02 AU-03 AU-06 PE-16 MP-04 SA-09 (05)	164.308(a)(1)(ii)(D) 164.308(a)(6)(ii) 164.312(b) 164.312(c)(2)			4.6.3.1 6.12.4 9.4.2.10 9.4.2.11 9.4.2.12 12.4.2.1 12.4.2.2 12.7.1.9	6.4 7.7 12.2	10.4, 10.4.1, 10.4.11, 10.4.2, 10.4.21, 10.4.3		CC7.1 CC7.3
SM-13	Systems Monitoring	Security Monitoring Alert Criteria Review	Organization reviews security monitoring alert on an annual basis.			X													X							8.1																		10.4, 10.4.1, 10.4.11, 10.4.2, 10.4.21, 10.4.3		
SM-14	Systems Monitoring	Log-tampering Detection	Organization monitors and flags tampering to the audit logging and monitoring tools in the production environment.			X	X			X							X		X	X						13.1	8.1.3.5 8.1.4.3				37							CA-07 (09)			12.5.1.18 14.1.3.5		10.3, 10.3.1, 10.3.2, 10.3.3, 10.3.4	1.4.1 8.1.3	
SM-15	Systems Monitoring	Unauthorized Devices Addition	Unauthorized devices connected to the Organization Network are: - detected within a maximum of five minutes, and - the unauthorized device is disabled, or a notification is sent to authorized Organization personnel			X											X		X							12.5 13.6												CM-08 (03)		ISM-0520			11.5, 11.5.1, 11.5.11, 11.5.2		
SM-16	Systems Monitoring	Security Monitoring Alert Criteria: Guest, Anonymous and Temp Accounts	Organization defines security monitoring alert criteria for the use of guest, anonymous, and temporary accounts on Organization's network.														X																				AC-02 (12)					12.7, 10.7.1, 10.7.2, 10.7.3, A3.3.1, A3.3.1.2 11.5, 11.5.1, 11.5.11, 11.5.2		
SM-17	Systems Monitoring	Security Monitoring Alert Criteria: VoIP Usage	Organization defines security monitoring alert criteria to detect deviations from Voice over IP (VoIP) activity standards.																X																										
SM-18	Systems Monitoring	Prohibited Activity Monitoring: Remote Access	Remote sessions are monitored for prohibited activity.				X								X	X	X			X		X					8.1.3.5								AC-17	AC-17	AC-17			6.2.2.5 6.2.2.8 6.2.2.20		11.5, 11.5.1, 11.5.11, 11.5.2		
SM-19	Systems Monitoring	Prohibited Activity Monitoring: Client Run Time Technologies	Organization monitors and flags the use of prohibited client run time technologies on information systems.																X																								11.5, 11.5.1, 11.5.11, 11.5.2		
SM-20	Systems Monitoring	Security Monitoring Alert Criteria: Wireless Access Point	Organization defines security monitoring alert criteria for attack attempts against wireless access points.				X												X								8.1.10.7 8.2.4.3																11.2, 11.2.1, 11.2.2		
SM-21	Systems Monitoring	Security Monitoring Alert Criteria: Failed Logins	Organization defines security monitoring alert criteria for failed login attempts on Organization's network.															X	X																			164.308(a)(5)(ii)(d)	ISM-1683 ISM-1684 ISM-1275				11.5, 11.5.1, 11.5.11, 11.5.2		
SM-22	Systems Monitoring	Security Monitoring Alert Criteria: Privileged Functions	Organization defines security monitoring alert criteria for privileged functions executed by both authorized and unauthorized users.				X										X		X								8.1.5.1 8.1.5.2 8.2.4.3										AC-06 (09) AC-06 (10)		ISM-1576 ISM-1275			10.2, 10.2.1, 10.2.11, 10.2.12, 10.2.13, 10.2.14, 10.2.15, 10.2.16, 10.2.17, 10.2.2		
SM-23	Systems Monitoring	Security Monitoring Alert Criteria: Audit Log Integrity	Organization defines security monitoring alert criteria for changes to the integrity of audit logs.																X																								10.3, 10.3.1, 10.3.2, 10.3.3, 10.3.4		
SM-24	Systems Monitoring	Security Monitoring Alert Criteria: Cardholder System Components	Organization defines security monitoring alert criteria for system components that store, process, transmit, or could impact the security of cardholder data and/or sensitive authentication data.																X																								10.4.10.4.1, 10.4.11, 10.4.2, 10.4.2.1		
SM-25	Systems Monitoring	System Security Monitoring	Critical systems are monitored in accordance with predefined security criteria and alerts are sent to authorized personnel. Confirmed incidents are tracked to resolution.	X	X		X	X		X		X			X	X	X	X		X	X	X	X	RS.AN-1 DE.AE-2 DE.CM-7 RS.AN-1	COS-01 COS-03 OIS-03 OPS-10 OPS-13 SIM-05 SSO-04 PSS-04		8.1.3.5 8.1.9.2 8.2.3.2	9.1(b)			33 34 35 46		8.16			AU-02 AU-05 AU-09 SI-04 SI-05	AU-02 AU-05 AU-09 SI-04 SI-05	AU-02 AU-05 AU-09 SI-04 SI-05 IR-06 (01)	164.308(a)(1)(ii)(D) 164.308(a)(5)(ii)(B) 164.308(a)(5)(ii)(C) 164.308(a)(6)(ii) 164.312(b) 164.312(c)(1) 164.312(c)(2)		6.1.3.5 9.4.2.10 9.4.2.11 9.4.2.12 12.4.5.5.P	7.7	12.10.1		CC6.8 CC7.2 CC7.3
SM-26	Systems Monitoring	Intrusion Detection Systems	Organization has an Intrusion Detection System (IDS) or Intrusion Prevention System (IPS) deployment(s) and ensures the following: - signature definitions are updated including the removal of false positive signatures - non-signature based attacks are defined - IDS/IPS are configured to capture malicious (both signature and non-signature based) traffic - alerts are reviewed and resolved by authorized personnel when malicious traffic is detected			X	X		X	X					X	X		X		X	X				8.11 13.3 13.8	8.1.3.3 8.1.3.4 8.1.4.4 8.1.4.5 8.2.2.1 8.2.3.2 8.2.4.3			Malware Protection	46					SI-04	SI-04	SI-04 SI-04 (01)		ISM-1213 ISM-1341 ISM-1034 ISM-1028 ISM-1030			11.5, 11.5.1, 11.5.11, 11.5.2	6.1.1 8.3.1 8.3.3	
SM-27	Systems Monitoring	System Monitoring Legal Opinion	Organization obtains legal opinion with regard to monitoring activities in accordance with applicable requirements and mandates.							X								X												46									ISM-0137 ISM-0979					
SM-28	Systems Monitoring	Privileged Session Monitoring	Organization monitors trusted data environments for unauthorized logical access connections.							X								X	X											46									ISM-1006	12.4.5.2.P		11.5, 11.5.1, 11.5.11, 11.5.2		
SM-29	Systems Monitoring	Availability Monitoring Alert Criteria	Organization defines availability monitoring alert criteria, how alert criteria will be flagged, and identifies authorized personnel for flagged system alerts.	X	X		X			X					X	X	X	X	X	X	X	X	X	DE.AE-5 PR.DS-4	OPS-01 OPS-02 OPS-09 PS-02		8.1.2.1				12 46 58 63 79 104 105 106				SI-05	SI-05	SI-05		ISM-1580 ISM-1446 ISM-1581 ISM-1290	12.1.3.9.PB	8.1	10.4.10.4.1, 10.4.11, 10.4.2, 10.4.2.1		CC3.1 CC7.2 A1.1
SM-30	Systems Monitoring	Availability Monitoring Alert Criteria Review	Organization reviews availability monitoring alert criteria on an annual basis.															X		X																			ISM-1580 ISM-1446 ISM-1581 ISM-1290			10.4.10.4.1, 10.4.11, 10.4.2, 10.4.2.1		
SM-31	Systems Monitoring	System Availability Monitoring	Critical systems are monitored in accordance with predefined availability criteria and alerts are sent to authorized personnel.	X	X			X		X		X			X	X	X	X	X	X	X	X	X	DE.CM-1 DE.DP-2	OPS-01 OPS-02 OPS-09 OPS-17 PS-06 SSO-04			9.1.0 9.1.(d) 9.1			12 46 58 63 79 104 105 106		8.6			SI-05	SI-05	SI-05 CP-02 (08)		ISM-1580 ISM-1446 ISM-1581 ISM-1290	12.1.3.1 12.1.3.2 12.1.3.3 12.1.3.4 12.1.3.5 12.1.3.6 12.1.3.7 14.1.1.8 17.2.1.1 17.2.1.2	8.1	10.4.10.4.1, 10.4.11, 10.4.2, 10.4.2.1		CC3.1 CC7.2 A1.1 A1.2
SM-32	Systems Monitoring	Remote Access: Activity Log Audit	Logs from remote sessions are audited for prohibited activity on a weekly basis.			X	X			X								X		X					8.11	8.1.3.5				46									ISM-1661 ISM-1662			10.4.10.4.1, 10.4.11, 10.4.2, 10.4.2.1		
SO-01	Site Operations	Secured Facility	Physical access to restricted areas of the facility is protected by walls with non-partitioned ceilings, secured entry points, and/or manned reception desks.	X	X		X			X		X			X	X	X	X	X	X	X	X	X	PR.AC-2 PR.IP-5	PS-01 PS-03 PS-04 PS-05 PS-06		8.1.10.1				50 51 55 56 83		7.1 7.3 7.6			PE-01 PE-02 PE-03 PE-16	PE-01 PE-02 PE-03 PE-16	PE-01 PE-02 PE-03 PE-16 MP-04 SA-09 (05)	164.310(a)(1) 164.310(a)(2)(ii)	ISM-1053 ISM-1530 ISM-0813 ISM-1074 ISM-0561	11.1.1.1 11.1.1.2 11.1.1.3 11.1.1.4 11.1.1.5 11.1.1.6 11.1.1.7 11.1.3.1 11.1.3.2 11.1.3.3 11.1.3.4 11.2.1.1 11.2.1.3 11.2.1.4 11.2.6.6	8.5	9.2, 9.2.1	11.1.1	CC6.4
SO-02	Site Operations	Physical Protection and Positioning of Cabling	Organization power and telecommunication lines are protected from interference, interception, and damage.		X		X			X		X			X	X	X		X		X				PS-06		8.1.1.1 (a) 8.1.1.3 (b) 8.1.1.10 (a) 8.1.1.10 (b) 8.3.1.1				52		7.1.2			PE-15	PE-15	PE-15 CP-08 (01) PE-09			11.2.3.1 11.2.3.2 11.2.3.3		9.2, 9.2.1		
SO-03	Site Operations	Global Coordination of Critical Functions: Information Security Safeguards	Organization consistently applies information security safeguards in datacenters and campuses.		X												X		X						PS-01													MP-04		ISM-1645			9.3, 9.3.1		
SO-04	Site Operations	Provisioning Physical Access	Physical access provisioning to an Organization datacenter requires management approval and documented specification of: - account type (e.g., standard, visitor, or vendor) - access privileges granted - intended business purpose - visitor identification method, if applicable - temporary badge issued, if applicable - access start date - access duration		X		X			X		X			X	X	X	X	X	X	X	X	X		PS-04		8.1.8.4				50		5.1.5			MA-05 PE-02 PE-03	MA-05 PE-02 PE-03 CM-05	MA-05 PE-02 PE-03	164.308(a)(4)(ii)(B) 164.310(a)(1) 164.310(a)(2)(ii) 164.310(a)(2)(iii)	ISM-1705 ISM-1706 ISM-1707 ISM-1708	11.1.2.1 11.1.2.3 11.1.2.4 11.1.2.5 11.1.2.6 11.1.2.7 11.1.2.8 11.1.2.9 11.1.2.10 11.1.2.11 11.1.2.12 11.1.2.13 11.1.6.5 11.2.1.2	8.5	9.3, 9.3.1, 9.3.1.1, 9.3.2, 9.3.3, 9.3.4	11.1.1 11.1.3	CC6.4
SO-05	Site Operations	De-provisioning Physical Access	Physical access that is no longer required in the event of a termination or role change is revoked. If applicable, temporary badges are returned prior to exiting facility.		X					X						X	X	X	X	X	X	X		PS-04						50					PE-02	PE-02	PE-02	164.310(a)(1) 164.310(a)(2)(ii)		7.1.1.1 7.1.1.2 7.1.1.3 9.2.6.1 11.1.2.1	8.5	9.3, 9.3.1, 9.3.1.1, 9.3.2, 9.3.3, 9.3.4		CC6.4

SO-06	Site Operations	Periodic Review of Physical Access	Organization performs physical account and access reviews on a quarterly basis; corrective action is taken where applicable		X					X					X	X	X	X	X	X	X	X		X		P5-04				'50					PE-02 PE-06 PS-05	PE-02 PE-06 PS-05	PE-02 PE-06 PS-05	164.310(a)(1) 164.310(a)(2)(ii) 164.310(a)(2)(iii)	ISM-1053 ISM-1530 ISM-0813 ISM-1074 ISM-0564	11.2.1 11.2.2.2	8.5	9.3, 9.3.1, 9.3.1.1, 9.3.2, 9.3.3, 9.3.4		CC6.4
SO-07	Site Operations	Physical Access Role Permission Authorization	Initial permission definitions, and changes to permissions, associated with physical access roles are approved by authorized personnel.							X		X			X	X	X		X	X		X								50		7.2			PE-03	PE-03	PE-03		ISM-1296 ISM-0564	11.1.5.5 11.1.5.6 11.1.6.1 11.1.6.2 11.1.6.3 11.1.6.4 11.1.6.6 11.1.6.7		9.3, 9.3.1, 9.3.1.1, 9.3.2, 9.3.3, 9.3.4		
SO-08	Site Operations	Monitoring Physical Access	Intrusion detection and video surveillance are installed at Organization datacenter locations; confirmed incidents are documented and tracked to resolution.		X		X			X		X					X	X		X	X	X		X		P5-03 P5-04		8.1.1.2 8.1.1.3 ⓘ		50		7.4					CP-08 PE-06 (III)	164.310(a)(1) 164.310(a)(2)(ii)		11.1.5.4 11.2.1.1	8.5	9.2.1.1		CC6.4
SO-09	Site Operations	Surveillance Feed Retention	Surveillance feed data is retained for 90 days.																	X																					9.2.1.1				
SO-10	Site Operations	Visitor Access	Physical access for visitors is managed through monitoring, maintaining records, escorting, and reviewing access monthly. Visitor access records to the facilities are kept for at least a year.				X								X	X	X			X							8.1.10.1								PE-03 PE-08	PE-03 PE-08	PE-03 PE-08					9.3, 9.3.1, 9.3.1.1, 9.3.2, 9.3.3, 9.3.4		
SO-11	Site Operations	Physical Access Devices	Physical access devices (i.e., keys, combinations, access cards, etc.) are maintained through an inventory and restricted to authorized individuals. Appropriate devices are rotated when compromised or upon employee termination or transfer.				X								X	X	X			X	X						8.1.1.2								PE-03	PE-03	PE-03					9.2.2, 9.2.3, 9.2.4	11.1.3	
SO-12	Site Operations	Temperature and Humidity Control	Temperature and humidity levels of datacenter environments are monitored and maintained at appropriate levels.		X		X			X		X			X	X	X			X	X		X	X		P5-05 P5-06 P5-07		8.1.10.1 8.1.11 (a) 8.1.11 (b) 8.1.14 (a) 8.1.14 (b) 8.1.14 ⓘ 8.1.1.8		50 52 53 54 55 56		7.5				PE-06 PE-14	PE-06 PE-14	PE-06 PE-14			11.1.4.1 11.2.1.1 11.2.1.7 11.2.1.7.7 11.2.2.3	8.5		11.2.2	A1.2
SO-13	Site Operations	Fire Suppression Systems	Emergency responders are automatically contacted when fire detection systems are activated, the design and function of fire detection and suppression systems are maintained at appropriate intervals.		X		X			X		X			X	X	X			X	X		X	X		P5-05 P5-07		8.1.10.1 8.1.1.5 (a) 8.1.1.5 (b) 8.1.1.5 ⓘ		50 55 56		7.5				PE-06 PE-13	PE-06 PE-13	PE-06 PE-13 PE-13 (D2)			11.2.1.1 11.2.1.5 11.2.1.6 11.2.1.8	8.5		11.2.2	A1.2
SO-14	Site Operations	Power Failure Protection	Organization employs uninterruptible power supplies (UPS) and generators to support critical systems in the event of a power disruption or failure. The design and function of relevant equipment is certified at appropriate intervals.	X	X		X			X		X			X		X	X	X	X	X		X	ID.BE-4		P5-06 P5-07		8.1.10.1 8.1.11 (a) 8.1.19 (a) 8.1.19 (b) 8.1.19 ⓘ		52 53 54		7.11						PE-11		ISM-1123	11.2.2.3 11.2.2.4 11.2.2.5 11.2.2.6 11.2.2.7	8.5		11.2.2	A1.2
SO-15	Site Operations	Emergency Shutoff	Organization employs emergency power shut-off capabilities. Access to shut off power is restricted to authorized individuals.				X																				8.1.10.1										PE-10							
SO-16	Site Operations	Emergency Lighting	Organization employs emergency lighting in the event of a power disruption or failure. The design and function of relevant equipment is certified at appropriate intervals.				X									X	X										8.1.10.1 8.1.1.4 (a) 8.1.1.4 (b) 8.1.1.7 (a) 8.1.1.7 (b)										PE-12	PE-12							
TA-01	Training and Awareness	General Security Awareness Training	Organization personnel complete security awareness training, which includes annual updates about relevant policies and how to report security events to the authorized response team. Records of training completion are documented and retained for tracking purposes.	X	X	X	X	X		X	X	X			X	X	X		X	X	X		X	PR.AT-1	AM-05 DEV-04 HR-02 HR-03 HR-04 SIM-04 SP-01	14.1 14.2 14.3 14.4 14.5 14.6 14.7 14.8	8.1.8.3 8.1.9.8 8.1.10.7	5.1(d)	2 3 32 60 61 62	5.1(d) 7.2 7.3(b) 7.3.D	6.2			AT-02 AT-04 IR-07	AT-02 AT-04 IR-07 AT-02 (D2)	AT-02 AT-04 IR-07 AT-02 (D2)	164.308(a)(5)(i) 164.308(a)(5)(ii)(A) 164.308(a)(5)(ii)(B)	ISM-0735 ISM-0252	4.5.2.3 4.5.2.4 4.5.2.5 4.5.2.6 4.5.2.7 6.2.1.20 6.2.2.6 7.1.2.1 7.1.2.10 7.2.1.1 7.2.1.2 7.2.1.3 7.2.1.4 7.2.1.5 7.2.1.6 7.2.2.1 7.2.2.2 7.2.2.3 7.2.2.5 7.2.2.6 7.2.2.7 7.2.2.8 7.2.2.9 7.2.2.10	3.6	12.6, 12.6.1, 12.6.2, 12.6.3, 12.6.3.1, 12.6.3.2, 6.3.1.4		CC2.2
TA-02	Training and Awareness	Code of Conduct Training	Organization full-time and temporary employees and interns complete a code of business conduct training.		X	X				X								X				X			AM-05 HR-02 HR-03 HR-04 HR-05	14.2 14.3 14.4 14.5 14.7 14.8			2 3 60 64 65 66 67										7.1.2.1 7.2.2.1 11.2.8.1				CC1.1
TA-03	Training and Awareness	Accessibility Training	Organization personnel complete accessibility awareness training, which includes annual updates about relevant policies and how to report accessibility events internally. Records of training completion are documented and retained for tracking purposes.				X												X								8.1.9.8												ISM-0877 ISM-0435					
TA-04	Training and Awareness	Phishing Awareness	Organization performs periodic phishing campaigns.			X																						9.5																	
TA-05	Training and Awareness	Developer Security Training	Organization's software engineers are required to complete training based on secure coding techniques on an annual basis.		X	X	X					X									X					DEV-04	14.9 16.9	8.1.9.4 8.1.4.2				8.25 8.28 6.3											6.2.4		
TA-06	Training and Awareness	Payment Card Processing Security Awareness Training	Organization personnel that interact with cardholder data systems receive awareness training to be aware of attempted tampering or replacement of devices. Training should include the following: - verify the identity of third-party persons claiming to be repair or maintenance personnel, prior to granting them access to modify or troubleshoot devices. - do not install, replace, or return devices without verification - be aware of suspicious behavior around devices (e.g., attempts by unknown persons to unplug or open devices) - report suspicious behavior and indications of device tampering or substitution to authorized personnel (e.g., to a manager or security officer)			X						X									X						14.9						6.3											9.5.1.3		
TA-07	Training and Awareness	Role-based Security Training HIPAA	Organization personnel with access to personal health information (PHI) are required to attend and complete HIPAA privacy training.			X						X							X								14.9					6.3								164.308(a)(5)(i) 164.308(a)(5)(ii)(A)					
TA-08	Training and Awareness	Role-based Security Training	Organization personnel with key security responsibilities complete relevant role-based training on an annual basis: - personnel must complete training prior to obtaining access to privileged security systems - personnel with contingency responsibilities must complete role-based training within 10 days of assuming the role - records of training completion are documented and retained for tracking purposes			X	X					X			X	X	X		X	X	X	X					14.9	8.1.8.3					6.3			AT-03 IR-02 CP-03	AT-03 IR-02 CP-03	AT-03 IR-02		ISM-1565 ISM-0408 ISM-0402	7.2.2.4 14.2.1.11 18.2.3.5		6.2.4	6.1.2	
TA-09	Training and Awareness	Security Champion Training	Service teams select a "Security Champion" to ensure security engagement responsibilities are assigned and tracked to completion; Security Champions receive training on how to execute responsibilities.			X						X															14.9					6.3													
TPM-01	Third-Party Management	Third-Party Assurance Review	On a periodic basis, management reviews controls within third-party assurance reports to ensure that they meet organizational requirements; if control gaps are identified in the assurance reports, management takes action to address impact the disclosed gaps have on the organization.	X	X	X	X	X		X		X			X	X	X	X	X	X	X	X	X	ID.SC-1 ID.SC-3 ID.SC-4	DEV-01 OIS-03 OIS-07 P5-01 P5-03 SSO-01 SSO-02 SSO-04 SSO-05	15.5 15.6	8.1.9.10 8.2.6.1 8.2.6.2	8.1.0 8.6.0		41 47 48 49		5.22			PS-07 SA-09	PS-07 SA-09 RA-03 (D1) SR-10	PS-07 SA-09 SA-09 (D1)	164.308(b)(2) 164.310(a)(1) 164.310(a)(2)(ii)	ISM-0731 ISM-1452 ISM-1569 ISM-0280 ISM-0285	4.6.2.5 6.1.1.12 14.1.1.13 14.2.1.12 14.2.6.6 14.2.7.2 14.2.7.3 14.2.7.4 14.2.7.5 14.2.7.6 14.2.7.7 14.2.7.8 14.2.7.9 14.2.7.10 14.2.7.11 15.1.1.2 15.1.1.3.F 15.1.1.3.P 15.1.1.7 15.2.1.2 15.2.1.3 15.2.1.4	3.4 6.4	12.8, 12.8.1, 12.8.2, 12.8.3, 12.8.4, 12.8.5	4.1.1 4.2.1	CC3.2 CC4.1 CC6.4 CC9.2
TPM-02	Third-Party Management	Vendor Risk Management	Organization performs a risk assessment to determine the data types that can be shared with a managed service provider.		X	X				X		X		X	X	X	X		X	X		X			SSO-02	15.3			1 2 3 8 9 10 40 41		5.19	A.5.2 A.7.1 A.10.12	PS-07 SA-09	PS-07 RA-03 (D1) SR-10	PS-07 SA-09 (D1)		ISM-1737 ISM-1638 ISM-1395 ISM-0072	15.1.1.6.B		12.8.3		
TPM-03	Third-Party Management	Forensic Investigations	Organization enables procedures to conduct a forensic investigation in the event that a hosted merchant or service provider is compromised.																	X	X																				12.8.3	4.2.1	
TPM-04	Third-Party Management	Privacy Risk Assessment	Organization reviews the privacy practices of service providers who access, collect, process, transfer, or store personal information on Organization's behalf upon initial procurement and renewal; non-compliance is tracked through remediation.				X												X	X							8.2.4.5												ISM-0280 ISM-0285	4.5.4.5				
TPM-05	Third-Party Management	Network Access Agreement: Vendors	Third-party entities which gain access to the Organization network sign a network access agreement.				X			X					X	X	X			X		X					8.1.8.4			40 60					PS-07	PS-07	PS-07				12.5.1.14 14.1.2.14 15.1.1.1 15.2.2.3 16.1.2.12		8.2.7		
TPM-06	Third-Party Management	Vendor Non-disclosure Agreements	Agency temporary workers, independent contractors, and third-party entities consent to a non-disclosure clause.	X	X	X	X			X		X			X	X	X	X		X	X	X	X	DE.CM-6	AM-05 HR-01 HR-05 HR-06 SP-01	15.4	8.1.8.4 8.2.6.1		1 2 3 8 9 10 40 41 87 88 89 90		6.6	A.10.1	PS-07	PS-07	PS-07			15.1.3 15.2.1 15.2.2 15.2.3 15.2.4 15.2.5 15.2.6 15.2.7 15.2.8 15.2.9 15.2.10 15.2.11 15.2.12 15.2.13 15.2.14 15.2.15 15.3.1 15.3.2 15.3.3 15.3.4 15.3.5		12.7, 12.7.1	2.2.1	CC9.2 C1.1
TPM-07	Third-Party Management	Cardholder Data Security Agreement	Organization managed service providers that manage, store, or transmit cardholder data on behalf of the customer must provide written acknowledgement to customers of their responsibility to protect cardholder data and the cardholder data environment.				X												X		X						8.1.10.14												ISM-1737 ISM-1638			12.9, 12.9.1, 12.9.2		
TPM-08	Third-Party Management	HIPAA Business Associate Agreement	Organization Business Associate Agreements must contain provisions for the following: - permitted uses and disclosures of Protected Health Information (PHI) - PHI safeguards to prevent unauthorized use or disclosure - communications regarding the unauthorized use or disclosure of PHI - PHI availability - contract termination and disposition of PHI														X																						164.308(b)(2) 164.308(b)(3) 164.314(a)(2)(i) 164.314(a)(2)(iii)					
TPM-09	Third-Party Management	HIPAA Business Associate Subcontractor Agreement	Organization requires a Business Associate Subcontractor Agreement with Business Associates from which it receives or transmits protected health information (PHI); Business Associates under contract are required to provide assurance that they adhere to Organization's security standards, which includes the security of PHI and reporting security events that potentially expose PHI.														X																						164.308(b)(2) 164.308(b)(3) 164.314(a)(2)(i) 164.314(a)(2)(iii)					

TPM-10	Third-Party Management	Network Service Level Agreements (SLA)	Vendors providing networking services to Organization are contractually bound to provide secure and available services as documented in SLAs.			X	X			X					X	X	X		X	X	X					15.4	8.1.9.10 8.1.10.14 8.2.6.1			4 24 25 71 72 73 74 75 76 77 94					PS-07	PS-07	PS-07		ISM-1575 ISM-1578	13.1.2.2 10.1.2.19 15.1.1.10 13.2.3.3 13.2.3.5		12.8.2, 12.8.5		
TPM-11	Third-Party Management	Personal Information Processing and Transfer Agreement	Appropriate data processing and transfer agreements are established for the collection, processing, transfer, or storage of personal information by, or on behalf of, Organization.			X	X					X		X		X			X	X						15.4	8.2.6.1								A.2.1 A.5.1 A.7.1 A.9.3 A.10.11			5.14		SR-08			ISM-0240 ISM-0866	13.2.2.2 13.2.2.3 13.2.2.4 13.2.2.5 13.2.2.6 13.2.2.7 13.2.2.8 13.2.2.9 13.2.2.10 13.2.2.11 13.2.2.12 13.2.2.13 15.1.2.2 15.1.2.4 13.2.1.8 13.2.1.9 13.2.1.14				
TPM-12	Third-Party Management	Approved Service Provider Listing	Organization maintains a list of approved managed service providers and the services they provide to Organization.		X	X	X										X		X	X			SSO-03	15.1	8.1.9.3 8.1.10.14 8.2.6.2														ISM-1756 ISM-1757 ISM-1637 ISM-1638			12.8.1	4.1.1 4.2.1	
TPM-13	Third-Party Management	Vendor Information Security Standard	Organization has documented a Vendor Information Security Standard that defines the responsibilities and governance requirements regarding vendor information security engagements. Contractual agreements are entered into with vendors who process or store Organization data that define Information Security terms and service level agreements.	X	X	X	X				X	X				X		X	X	X	X	X	X	ID.BE-1 ID.SC-3 ID.SC-4	COM-01 HR-06 OIS-02 OIS-03 SRM-04 SSO-01 DEV-02	15.2 15.4	8.1.9.3 8.1.9.10 8.1.10.14				7.3	5.2 5.23 5.21					SR-01 SR-02 SR-02 (09) SR-03 SR-05			164.308(a)(1)(i)	ISM-1568 ISM-1632 ISM-1571 ISM-1758 ISM-1073 ISM-0280 ISM-0285 ISM-1578	13.1.2.1 13.2.4.3 14.2.7.1 6.1.1.13.PB 7.1.2.4 7.1.2.5 15.1.1.3 15.1.1.4 15.1.1.6 15.1.1.7 15.1.1.8 15.1.1.9 15.1.1.12 15.1.2.3 15.1.2.5 15.1.2.6 15.1.2.7 15.1.2.8 15.1.2.9 15.1.2.10 15.1.2.11 15.1.2.12 15.1.2.13 15.1.2.14	3.4	12.8	1.2.2 2.2.1 4.1.1	CC1.3 C1.1
VM-01	Vulnerability Management	Vulnerability Scans	Organization conducts vulnerability scans against the production environment; scan tools are updated prior to running scans.	X	X	X	X		X	X		X			X	X	X	X	X	X	X	X	X	DE.CM-8 PR.IP-12 ID.RA-1	COM-03 COS-03 OPS-18 OPS-20 OPS-22 PSS-02 PSS-09 PSS-03	7.5 7.6	8.1.7.5 8.1.10.5		Security Update Management	4 27 28 29 88 89 90		8.8			CA-07 RA-05 SI-02 RA-05 (02)	CA-07 RA-05 SI-02 RA-05 (02)	CA-07 RA-05 SI-02 RA-05 (02) RA-05 (03)	164.308(a)(1)(i)(A) 164.308(a)(1)(i)(B) 164.308(a)(8)	ISM-1163 ISM-1698 ISM-1699 ISM-1700 ISM-1701 ISM-1702 ISM-1752 ISM-1754	12.6.1.1 12.6.1.2 12.6.1.3 12.6.1.4 12.6.1.5 12.6.1.6 12.6.1.7 12.6.1.8 12.6.1.9 12.6.1.10 12.6.1.11 12.6.1.12 12.6.1.13 12.6.1.14 12.6.1.15 12.6.1.16 12.6.1.17 14.2.9.3 18.2.3.3 18.2.3.4	11.3 13.1	11.3, 11.3.1, 11.3.1.1, 11.3.1.2, 11.3.1.3, 11.3.2, 11.3.2.1	3.3.1 8.1.5	CC3.2 CC7.1
VM-02	Vulnerability Management	Vulnerability Scans: Cardholder Data Environment	Vulnerability scans are conducted against cardholder environments at least quarterly or after significant change; critical vulnerability resolution is confirmed via a rescan.														X			X																			ISM-1608 ISM-1588 ISM-1698 ISM-1699 ISM-1700 ISM-1701 ISM-1702 ISM-1752		11.3, 11.3.1, 11.3.1.1, 11.3.1.2, 11.3.1.3, 11.3.2, 11.3.2.1		
VM-03	Vulnerability Management	Vulnerability Scans: Audit Log Review	When vulnerabilities are identified, Organization analyzes audit logs to see if it has been previously exploited. Identified exploitations are resolved through incident management.			X	X										X			X						18.4	8.1.10.5													ISM-0298 ISM-1643 ISM-1690 ISM-1694 ISM-1695 ISM-1696 ISM-1697 ISM-1698 ISM-1699 ISM-1700 ISM-1701 ISM-1702 ISM-1752 ISM-0109 ISM-1228 ISM-1616 ISM-1755 ISM-1756			12.10		
VM-04	Vulnerability Management	Vulnerability Scans: Trend Analysis	Organization reviews vulnerability trends over time to include in risk assessments; high and moderate risk vulnerabilities are remediated in 30 and 90 days, respectively.			X	X								X	X	X		X							18.4	8.1.7.5									RA-05	RA-05	RA-05		ISM-0298 ISM-1643 ISM-1690 ISM-1694 ISM-1695 ISM-1696 ISM-1697			11.3, 11.3.1, 11.3.1.1, 11.3.1.2, 11.3.1.3, 11.3.2, 11.3.2.1		
VM-05	Vulnerability Management	Approved Scanning Vendor	At least quarterly, Organization engages an Approved Scanning Vendor to conduct external vulnerability scans.		X											X	X	X			X				COS-03 OPS-22										RA-05	RA-05	RA-05 CA-08 (01)					11.3, 11.3.2.1		
VM-06	Vulnerability Management	Application Penetration Testing	Organization conducts penetration tests periodically.		X	X				X						X	X	X		X	X	X		X		COM-03 OPS-18 OPS-19 OPS-20 PSS-02 OIS-05	16.13 18.1 18.2 18.5				4 27 28 29 88 89 90					CA-07 SI-03	CA-02 (01) CA-07 SI-03 CA-08	CA-02 (01) CA-07 SI-03 CA-08	164.308(a)(1)(i)(A) 164.308(a)(1)(i)(B) 164.308(a)(8)		14.2.9.4	13.2 13.3	11.4.1, 11.4.2, 11.4.3, 11.4.4, 11.4.5, 11.4.6, 11.4.7, A11.4, A12.4		CC4.1 CC7.1
VM-07	Vulnerability Management	Application Penetration Testing: Cardholder Data Environment	Organization conducts penetration tests against cardholder data environments (CDE) and includes the following requirements: - testing covers the entire CDE perimeter and critical data systems - testing verifies that CDE perimeter segmentation is operational - testing is performed from both inside and outside the CDE network - testing validates segmentation and scope-reduction controls (e.g., tokenization processes) - network layer penetration tests include components that support network functions as well as operating systems - at the application level, testing provides coverage, at a minimum, against the security testing requirements defined in VM-06-01 (01) - testing is performed with consideration of threats verified in the last 12 months from external alerts, directives, and advisories defined in VM-06-02 - testing is performed with consideration of vulnerabilities reported through Organization's PSIRT process within the last 12 months - risk ratings are assigned to discovered vulnerabilities, which are tracked through remediation														X			X																	CA-08 (01)					6.4.1, A11.4		
VM-08	Vulnerability Management	Infrastructure Patch Management	Organization installs security-relevant patches, including software or firmware updates; identified end-of-life software must have a documented decommission plan in place.		X	X	X		X						X	X	X	X	X	X	X	X	X		OPS-22	7.3 7.4	8.1.4.4		Security Update Management						CA-07 SI-02	CA-07 SI-02	CA-07 SI-02 CM-08 (01)	164.312(c)(1)	ISM-1407 ISM-1744 ISM-1467 ISM-1483 ISM-1606 ISM-1143 ISM-0298 ISM-1643 ISM-1690 ISM-1691 ISM-1692 ISM-1693 ISM-1751 ISM-0300 ISM-1757	12.5.1.11 12.5.1.15	7.3 7.4 11.4	6.3.2, 6.3.3	8.1.4 8.1.5 8.3.1	CC7.1
VM-09	Vulnerability Management	Enterprise Antivirus	Organization has managed enterprise antivirus deployments to detect and respond to malicious activities.	X	X	X		X	X			X			X	X	X	X	X	X	X	X	X		OPS-04 OPS-05	9.7 10.1 10.2 10.3 10.4 10.6 10.7	8.1.10.7		Malware Protection	31		8.7			CA-07	CA-07	CA-07	164.308(a)(5)(i)(B)	ISM-0917 ISM-1745 ISM-1417 ISM-1472 ISM-1288 ISM-0657	12.2.1.1 12.2.1.3 12.2.1.4 12.2.1.6 12.2.1.8 12.2.1.13	11.3	5.2, 5.2.1, 5.2.2, 5.2.3, 5.2.3.1	8.2.1	CC6.8
VM-10	Vulnerability Management	Enterprise Antivirus Tampering	Antivirus mechanisms cannot be disabled or altered by users unless specifically authorized by management.														X			X																			ISM-1672			5.3.5		
VM-11	Vulnerability Management	Enterprise Antivirus Scope	Vulnerability scans are periodically performed on systems that do not require anti-virus; management determines if anti-virus should be required on the system based on scan results and associated risk.						X											X									Malware Protection														5.2, 5.2.1, 5.2.2, 5.2.3, 5.2.3.1		
VM-12	Vulnerability Management	Maintenance Tools: Inspect Media	Organization checks media containing diagnostic and test programs for malicious code before the media are used in production systems.				X													X							8.1.10.7																6.2.3.1		
VM-13	Vulnerability Management	Code Security Check	Organization conducts periodic source code checks for vulnerabilities.			X				X		X			X	X	X		X	X	X					16.12				8 9 10 87		5.8 8.25 8.29			CA-07 SI-03	CA-07 SI-03	CA-07 SI-03		ISM-1460 ISM-1604	14.2.1.8 14.2.1.9		6.2.3.1		
VM-14	Vulnerability Management	Code Security Check: Cardholder Data Environment	Where applicable, security testing performed prior to releasing code into production includes the following: - code injection - buffer overflows - insecure cryptographic storage - insecure communications - improper error handling - high-risk vulnerabilities - cross-site scripting - improper access control - cross-site request forgery - broken authentication session management			X	X										X			X							16.12	8.1.9.7													ISM-1669 ISM-1542 ISM-0402 ISM-0975			6.2.4		
VM-15	Vulnerability Management	Third-Party Library Check	Organization scans third-party libraries for vulnerabilities according to the service risk rating assignment.			X														X						16.5																6.3.1		
VM-16	Vulnerability Management	Non-disclosure of Error Detail	Information systems are designed to ensure error messages generated provide adequate information for taking corrective action without revealing sensitive information.															X		X																	SI-11					6.2.4		
VM-17	Vulnerability Management	Embedded Authenticators	Quality Engineering checks to ensure that static passwords are not embedded within application source code or access scripts, prior to deployment on the Organization network.														X			X																	ISM-1460 ISM-1604			6.2.3.1		
VM-18	Vulnerability Management	External Information Security Inquiries	Organization reviews information-security-related inquiries, complaints, and disputes.																	X																						6.3.1		
VM-19	Vulnerability Management	External Alerts and Advisories	Organization reviews alerts and advisories from management approved security forums and communicates verified threats to authorized personnel.		X					X		X				X				X					OIS-05					3 32 36 60		5.5 5.6				RA-05 (11)			ISM-0298 ISM-1643 ISM-1690 ISM-1691 ISM-1692 ISM-1693 ISM-1694 ISM-1695 ISM-1696 ISM-1697			6.3.1		
VM-20	Vulnerability Management	Third-Party Security Assessment	Organization engages qualified managed service providers to perform independent information security assessments.															X				X															CA-07 (01) SA-11 SA-11 (02)			6.3.1		
VM-21	Vulnerability Management	Security Testing Window	Security administrators notify relevant parties prior to executing technical security assessments; assessment details and results are documented in a ticket.															X																			SA-11					

VM-22	Vulnerability Management	Vulnerability Remediation	Organization assigns a risk rating to identified vulnerabilities and prioritizes remediation of legitimate vulnerabilities according to the assigned risk.			X				X					X	X	X			X		X	X				7.2 7.7 16.2 16.6 18.3				4 27 28 29 88 89 90					CA-07 RA-05	CA-07 RA-05	CA-07 RA-05			12.6.1.1		6.3.1	3.3.1	
VM-23	Vulnerability Management	Backlog Prioritization	Organization documents identified bugs, prioritize bug fixes according to risk, and tracks resolution as part of the product release cycle.			X	X															X					7.2 7.7 16.2	8.1.9.5														6.3.1		